

Full length article

A provider-agnostic security framework for PKI-based electronic identity systems: A Swedish case study

Qinghua Wang^{a,*}, Omar Zarifa, Nedim Kanat

Department of Computer Science, Faculty of Natural Science, Kristianstad University, Kristianstad, SE-29188, Sweden

ARTICLE INFO

Keywords:

Electronic identity (eID)
Authentication protocols
Public key infrastructure (PKI)
Security invariants
Lifecycle governance
eIDAS

ABSTRACT

This article develops a provider-agnostic security framework for public key infrastructure (PKI)-based electronic identity (eID) systems and applies it to two mature Swedish deployments, BankID and Freja eID. We formalize the canonical user journeys—same-device and cross-device authentication and signing—as compact state-machine models, including a middleware variant. From these models, we derive three protocol-level invariants that govern semantically correct execution: freshness of challenges and results, strict session/origin binding, and dynamic linking of user-approved authorization content. We then evaluate how platform features and relying-party integrations enforce these invariants and analyze documented incidents through the same lens. The results show that both ecosystems rely on robust PKI foundations and provide the technical means to satisfy the invariants; real-world harm arises primarily from intent deception, lifecycle abuse, integration weaknesses, and incomplete verifier-side enforcement rather than cryptographic failure. The proposed framework explains these patterns, clarifies which controls are essential, and offers a reusable analytical tool applicable beyond the Swedish context to other PKI-based electronic identity systems.

1. Introduction

1.1. Context and objective

In today's digital age, where much of our daily lives unfolds online — from paying bills to virtual doctor visits — safeguarding digital identities has become essential. Across Europe, digital/electronic identity (eID) is delivered through nationally operated or nationally governed schemes with cross-border recognition under the eIDAS regulation (European Union, 2024). Many Member States have notified their schemes to the European Commission so they can be recognized abroad by other public services in the EU. Examples include Denmark's MitID (MitID partnership, 2025), Germany's eID function on the national ID card (Federal Ministry of the Interior, Germany, 2025), the Netherlands' DigiD (Logius, 2025), and other notified schemes in Belgium, Croatia, Cyprus, Estonia, Norway, Italy, Luxembourg, Lithuania, Poland, Portugal, Romania, Spain, Sweden, and Austria, etc (European Union, 2023). Sweden relies on privately operated providers — BankID (Finansiell ID-Teknik BID AB, 2025a) and Freja eID (Freja eID Group AB, 2025) — that operate within the Swedish eID framework (Svensk E-Identitet, 2021; Sweden Connect, 2020); Freja eID Plus was Sweden's first eID announced for EU cross-border use in 2021 (Freja, 2025), and BankID was published in the EU

Official Journal in January 2025 (BankID, 2025b), triggering EU-wide public-sector acceptance within twelve months.

A growing peer-reviewed literature has analyzed the real security posture of such systems. For Denmark, a user-centric study of MitID (Kingo and Aranha, 2023) shows that early versions were vulnerable to social engineering and denial-of-service attacks that could be mounted without privileged access, highlighting risks beyond cryptographic design. Early analyses of Norway's BankID (prior desktop era) (Gjøsteen, 2008) reported cryptographic and protocol weaknesses enabling man-in-the-middle and insider attacks. Early work on the Belgian eID (Verhaeghe et al., 2009) identified single-sign-on abuse and privacy leaks — leading to protocol hardening proposals. For Estonia's ID-card, researchers uncovered a vulnerability in the RSA key-generation implementation used in the card's secure hardware, which enabled recovery of private keys from public certificates (the so-called ROCA vulnerability) (Parsovs, 2020). The weakness did not stem from a break of the RSA algorithm itself, but from flaws in key-generation procedures and deployment practices, underscoring that implementation discipline and operational governance are as critical as the choice of cryptographic primitives. Together, these studies demonstrate that the security of national eID systems depends not only on the strength of cryptographic primitives, but also on implementation discipline,

* Corresponding author.

E-mail addresses: qinghua.wang@hkr.se (Q. Wang), omar.zarifa0004@stud.hkr.se (O. Zarifa), nedim.kanat0015@stud.hkr.se (N. Kanat).

integration correctness, lifecycle governance, and the faithful alignment between user intent and authorization effect.

In response to these observations, this article develops and validates a provider-agnostic security model for online eID. We define explicit system and attacker models and express the two canonical user journeys—approval on the same device as the service client and cross-device approval—as compact state machines, with and without middleware. We analyze the two security-critical purposes of these journeys—identification (login) and authorization (signature)—and derive the invariant properties required to make them semantically safe. Finally, we evaluate how current identity-provider (IdP) and relying-party (RP) practices uphold these properties in real deployments.

1.2. Contributions

This article (i) presents a concise, provider-agnostic system and attacker model for online eID identification and signature; (ii) specifies compact state-machine models for same- and cross-device flows—including a prompted (another-user-initiated) variant and a middleware variant; (iii) conducts a scenario-based threat analysis over these models; (iv) corroborates the analysis with a thematic coding of public incidents and derives incident-informed countermeasures; and (v) offers a critical evaluation of BankID and Freja eID controls (security and fraud-prevention), clarifying verifier duties for identification and signature.

1.3. Scope and focus

This study concentrates on the two canonical user journeys—same-device and cross-device—and on their two security-critical purposes—identification (login) and signature (authorization). We chose this scope for three reasons. First, these journeys are the dominant operational modes in the two ecosystems BankID and Freja eID, and they capture the essential architectural difference that drives security properties: whether the user approves on the same device that initiated the session, or on a second device via a short-lived, machine-readable challenge. Second, the majority of observed incidents and controls map directly to these journeys: intent deception, session and origin binding, quick-response (QR) code freshness, and dynamic linking of a human-readable action text are all exercised most clearly in login and signing. Third, this focus enables a formal yet tractable analysis: we can define state machines and attacker capabilities once, prove properties about freshness, binding, and purpose text, and then validate them against real incidents and middleware integrations.

Other operational modes offered by BankID and Freja eID are either special cases or surface the same security invariants through a different presentation. Telephone identification is a login flow with out-of-band prompting; the digital identity card reduces to cross-device verification when a verifier scans the code; data-sharing and attribute release are governed by the same consent and signing semantics; and device lifecycle and recovery actions are best modeled as signing flows with stronger step-up and cool-off. Even platform variants (for example “on card” or “on file”) change the key container and usability, but not the logic of same-device versus cross-device approval or the need for strict session/origin binding and dynamic linking.

This scoped analysis is therefore sufficient to capture the principal risks and defenses in practice while keeping the model testable and comparable across providers. We note, however, that specialized deployments (for example face-to-face verification without online scanning, or bespoke enterprise flows) may require additional operational controls; we discuss these as limitations and avenues for future work rather than expanding the core model.

2. Background

2.1. Authentication essentials

Authentication establishes who is acting; authorization governs what that actor may do. Practical authentication combines factors from four families—something you know (for example a password or PIN digits), something you have (for example a mobile app, smart card, or hardware token), something you are (for example fingerprint or face), and sometimes something you do (for example voice or signature dynamics). Contemporary web systems commonly use multi-factor authentication and federated single sign-on: an identity provider (IdP) authenticates the user and issues a signed assertion that the relying party (RP) verifies for freshness and integrity before granting access or authority.

2.2. Levels of assurance

A level of assurance expresses confidence that the authenticated subject is the claimed person. Frameworks differ in labels—eIDAS (European Union, 2024) uses *Low*, *Substantial*, *High*; Sweden’s national framework (Svensk E-Identitet, 2021; Sweden Connect, 2020) aligns with tiers akin to *LoA1–LoA4*—but the logic is consistent: higher levels require stricter enrollment (identity proofing) and stronger authenticators. *Low* may allow self-registration with minimal checks; *Substantial* requires verified identity data and at least two factors; *High* demands rigorous identity proofing (often in person) and a secure authenticator under the user’s sole control. Selection of LoA depends on RP policies.

2.3. BankID and Freja eID

BankID (Finansiell ID-Teknik BID AB, 2025a) is Sweden’s bank-backed electronic identity system, launched in 2003 and owned by Finansiell ID-Teknik BID AB, a company governed by a consortium of major Swedish banks. It is built on public-key infrastructure and offered in three forms. *Mobile BankID* is a smartphone application that stores the user’s private key within the app and protects it with a personal code or biometrics. *BankID on file* denotes the desktop-installed variant, in which the user’s certificate and corresponding private key are stored locally as a file on a personal computer and protected by a password together with a desktop security application. *BankID on card* stores the private key on a smart card that is unlocked with a personal code using a card reader and a desktop security application. Service providers can integrate BankID either by contracting directly with a BankID-issuing bank or via a certified integrator. Functionally, BankID supports digital identification (for logging in or proving identity, including during telephone calls), digital signatures (legally binding approvals), and a digital identity card for face-to-face checks. The identity card can be verified visually or by scanning an animated QR code with another device or a connected scanner to confirm validity online in real time.

Freja eID (Freja eID Group AB, 2025) is a Swedish electronic identity service from Freja eID Group AB (formerly Verisec AB), now offered as a cloud identity platform. It provides several assurance levels and use cases. “Basic” accounts require only email registration and offer low assurance. “Extended” uses identity-document scanning and a biometric selfie check and corresponds to a medium assurance level. “Plus” is the highest assurance; in Sweden it can be completed digitally with a passport, national identity card, or driver’s license, while some users complete a physical identity check (for example at authorized shops). Freja also offers Freja OrgID for organizations, allowing employees or members to authenticate to work systems while keeping private and professional identities separate; a number of municipalities, universities, and companies in Sweden use this. Integration is available either directly with Freja or through an integrator, and commercial tiers range

Table 1

Modes and assurance at a glance (BankID and Freja eID).

System & variant	Private-key location	User approval	Assurance characteristics (summary)	Typical use
BankID — Mobile	Inside the mobile app	PIN and/or biometric in the app; same-device deep link or cross-device scan of an animated, short-lived code	App-bound key; strong user-presence cues; relies on short-lived, single-use start flows and relying-party verification	Everyday login and legally binding signing
BankID — On file	Encrypted file on a desktop	Password via the BankID security application	Depends on desktop hygiene; convenient but inherits endpoint risks	Legacy desktop login/signing where allowed
BankID — On card	Smart card (reader + PIN)	PIN on card reader with desktop security application	Hardware-backed isolation; strong physical control; higher operational overhead	Regulated or high-assurance environments
Freja — Basic	App account (email-based)	App approval (no verified identity document)	Low assurance; suitable only for low-risk contexts	Low-value logins
Freja — Extended	App with verified ID document + biometric selfie	App approval; enrollment vetted by document scan and biometric match	eIDAS “Substantial”/LoA2 at enrollment; two-factor at use	Medium-risk services
Freja — Plus	App with high-assurance enrollment (digital document or in-person check)	App approval; strongest enrollment vetting	eIDAS “High”/LoA3; intended for sensitive actions	High-risk services and official use
Freja — OrgID	App, issued under an organization	App approval; job identity	Assurance per organization policy (commonly substantial/high) with role scoping	Enterprise and public-sector systems

from end-user free options to tailored organizational packages. Feature-wise, Freja supports QR code identification on desktop and mobile (matching cross-device and same-device patterns), electronic signatures, a digital identity card for physical checks that can be validated online by scanning, consent-based data sharing to provision verified attributes (such as addresses), “Shared Control” where a trusted person co-approves actions, user self-service through “My Pages”, and the ability to use multiple devices.

The different modes of operations and their use cases are summarized in Table 1.

Neither BankID nor Freja eID publish their algorithm details. We have sent inquiries via email to BankID technical team and to Freja eID support, both have replied and stated that they would not confirm the specific cryptographic algorithms in use. Given that both BankID and Freja eID are compliant with the Sweden Connect technical framework (Sweden Connect, 2024), it is inferred that their cryptographic infrastructure aligns with the mandatory algorithms listed in the trust framework provided by the Swedish Agency for Digital Government (The Swedish Agency for Digital Government Digg, 2024). The algorithms specified there include: digest algorithms (Mandatory: SHA-256; Optional: SHA-384/512), signature algorithms (Mandatory: RSA-SHA256, ECDSA-SHA256; Optional: RSA-SHA384/512, ECDSA-SHA384/512), block ciphers (Mandatory: AES128/192/256-CBC; Optional: AES128/192/256-GCM), and key transport algorithms (Mandatory: RSA-OAEP-MGF1P with SHA-1 digest; Optional: RSA-OAEP-MGF1P with SHA-256/384/512.). Further, the framework requires that RSA public keys must be at least 2048 bits in length (while 3072 bits or more is recommended), and EC public keys must be at least 256 bits in length (signature only). These are well-known commercial standard algorithms and are considered secure at the time of writing. The continued use of RSA-OAEP-MGF1P with SHA-1 as a key transport algorithm warrants clarification. Although SHA-1 is known to have practical collision-resistance weaknesses, such attacks primarily affect signature schemes that rely on collision resistance and do not directly translate into practical breaks of RSA-OAEP encryption. Nevertheless, contemporary cryptographic guidance discourages the use of SHA-1 in new designs, and SHA-256-based alternatives are generally preferred. After reviewing the developer documentation, we can confirm that SHA-256 and RSA-SHA256 are currently used by both BankID (BankID Developers, 2025b) and Freja eID (Aleksandar Laban, 2025), while AES256-CBC is at least used by Freja eID (Aleksandar Laban, 2023). For secure communication and certificate-based authentication, both services indicate in their publicly available documentation that TLS/SSL is used (BankID Developers, 2025a; Dragoljub Nesic, 2025).

Both BankID and Freja eID Plus meet Sweden’s national eID framework, holding the DIGG “Svensk e-legitimation” quality mark at LoA 3 (the highest currently feasible for mobile solutions; Level 4 would require hardware tokens and in-person renewal) (DIGG, 2026). At EU level, Freja eID Plus and BankID are notified under eIDAS at *Substantial* assurance; Freja was listed in 2021 (Freja, 2025), and BankID was published in the EU official journal in January 2025 (BankID, 2025b), triggering mandatory acceptance by EU/EEA public-sector services within twelve months. Both systems support electronic signatures under eIDAS and align with PSD2 Strong Customer Authentication and GDPR consent and control requirements (BankID, 2025a; Freja, 2025). Internationally, BankID also holds ISO/IEC 27001 certification for its information security management system.

2.4. Related work on other national eID systems

National eID systems across Europe and beyond adopt a wide range of technical architectures and assurance mechanisms. A recent survey by Sharif et al. (2022) provides a comparative analysis of eID schemes notified under eIDAS, highlighting technological diversity in authentication methods, assurance levels, and interoperability models. Reported techniques include:

- Password-based authentication combined with SMS one-time passwords (OTP),
- Smartcard-based PKI solutions,
- Crypto-SIM-based authentication,
- Mobile app-based authentication using embedded private keys,
- Hybrid approaches combining biometrics and device binding.

This heterogeneity reflects differing national regulatory traditions and infrastructure constraints.

Among these approaches, two dominant architectural families can be identified: 1. Knowledge/possession-based multi-factor authentication without end-user certificate management, often relying on OTP (e.g., password + SMS), and 2. Public-key infrastructure (PKI)-based identity systems, where users possess a private key bound to an identity certificate, enabling cryptographic authentication and qualified electronic signatures.

The Swedish systems studied in this article — BankID and Freja eID — belong to the second category. Similar PKI-based national eID ecosystems include:

- Estonian ID-card, Mobile-ID, and Smart-ID, which rely on certificate-based authentication and digital signatures anchored in a national PKI infrastructure (Parsovs, 2020; Sharif et al., 2022).

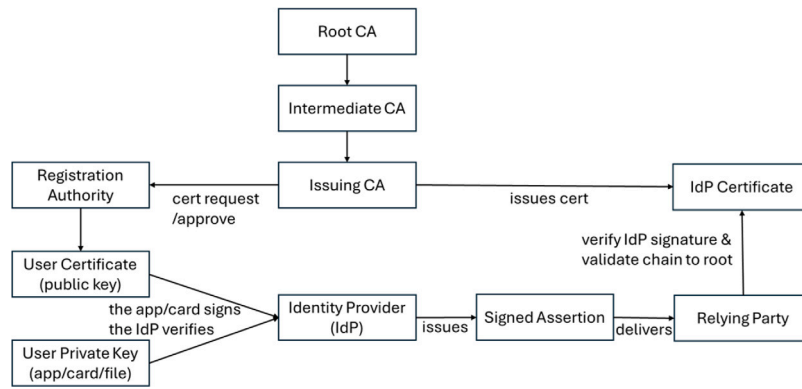


Fig. 1. PKI with user certificate issuance and key-possession proof.

- German eID (nPA), which uses a chip-based identity card with cryptographic challenge–response authentication under a national trust framework (Bundesamt für Sicherheit in der Informationstechnik (BSI), 2026).
- Belgian eID, which has been analyzed for its PKI structure and security properties (Verhaeghe et al., 2009).
- Norwegian BankID (earlier generation), which has been examined for protocol weaknesses and PKI deployment characteristics (Gjøsteen, 2008).

Although implementation details differ (smartcards vs. mobile apps vs. SIM-based secure elements), these PKI-enabled systems share a common logical structure: One RP generates a fresh authentication or signing request; the IdP verifies user control over a private key; a signed assertion or signature result is returned to the RP; the RP verifies certificate chains, freshness, and bindings before granting access or effect.

This structural similarity suggests that the state-machine abstraction proposed in this paper — modeling same-device and cross-device approval flows and enforcing invariants such as freshness, session/origin binding, and dynamic linking — is directly applicable to other PKI-based national eID systems with minimal adaptation.

By contrast, OTP-only systems (e.g., password + SMS) do not natively support cryptographic signing or dynamic linking of transaction content, and therefore exhibit different security properties. While our model can describe their session lifecycle at an abstract level, its signature-specific invariants are most naturally satisfied in certificate-based architectures.

In this sense, BankID and Freja eID serve as representative instances of a broader class of PKI-enabled eID ecosystems rather than as isolated national cases.

Early academic analyses of national digital identity infrastructures have also examined governance and multi-provider trust relationships. For example, (Buccafurri et al., 2015) discusses security challenges in the Italian digital identity system (SPID), including issues arising from multiple identity providers and federated trust models. While such work highlights architectural and governance concerns, our contribution differs in that we formalize provider-agnostic operational flows as state machines and derive explicit protocol-level invariants and supporting properties that are then validated against real-world incidents.

2.5. Public-key infrastructure (PKI) primer

The Swedish and many other national eID systems rely on PKI infrastructure. Fig. 1 shows a lighter version of the PKI certificate chain and key possession proof process. At the enrollment stage, the issuing CA (the bank consortium’s CA for BankID; Freja eID Group’s CA for Freja) via a registration authority (for example a bank or an in-person

check) issues a user’s certificate. The certificate contains the user’s public key and identity data. The private key is generated and kept inside the user’s secure container (app, card, or file) and never leaves it. At the authentication stage, the user proves her/his key possession (typically via a challenge-response) to the IdP; the IdP issues a signed assertion; the RP verifies the assertion’s signature and the IdP certificate chain (to Root CA), and consults revocation before accepting login or signature.

3. Methodology

We adopt a design-oriented, analytical method in three steps.

First, we formalize the problem with an abstract system model and a realistic attacker model, and we express both same-device and cross-device flows as state machines (with and without middleware). From these, we derive three invariant properties that must hold for security: freshness of challenges and assertions, binding of results to the initiating session and site origin, and dynamic linking of a short, human-readable action text that the user approves.

Second, we perform a scenario-based security analysis, identifying most relevant threats defined in the attacker model, conducting vulnerability analysis, and giving suggestions to controls that can reduce risks.

Third, we conduct a thematic analysis of reported real-world incidents, coding each case to attacker types (e.g., intent deception, relay/misbinding, lifecycle abuse, denial of service, and relying-party gaps). We use this coding to triangulate the model, prioritize practical controls, and test whether our recommendations address the ways harm actually occurs.

All sources are publicly available documents and reports; no personal data were collected.

4. Threat modeling for online eID identification and signing

4.1. System model

An online service, which is the RP, relies on a national or pan-European digital identity application (or IdP) to confirm who the user is and, when needed, to have the user sign or approve a specific action. Three parties are involved.

First, the service/RP runs a public web site or application that the user is trying to access. It also has a back-end that opens an “authentication request”, keeps track of time limits, and binds the eventual identity result to the user’s browser session.

Second, the user’s devices carry out the visible steps. On a single phone, the browser can deep-link directly to the identity application (same-device). On a desktop or laptop, the service shows a short-lived QR code that the user scans with the phone that has the identity application installed (cross-device). In both cases, the user proves presence on the phone by a biometric or a personal identification number.

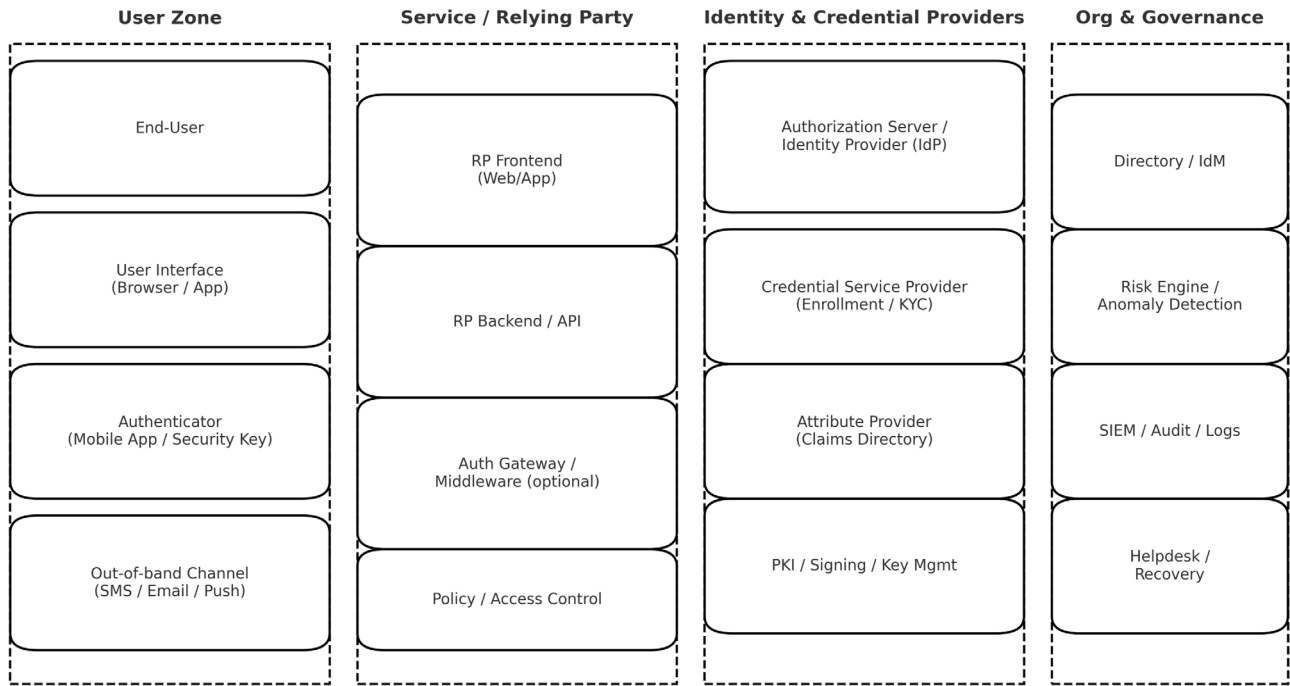


Fig. 2. Abstract of a generic eID authentication ecosystem.

Third, the IdP receives the phone's authentication, checks the result, and returns a signed identity assertion to the service. The service verifies the signature and the bindings, then either opens a session or completes the requested signature or approval.

The interaction patterns described above are instantiated as state-machine operation models in Section 5. At a conceptual level, secure operation requires three dimensions of correctness: temporal correctness (start tokens must be short-lived and single-use), contextual correctness (results must be bound to the initiating request, session, and origin), and—when a concrete action is approved—semantic correctness (the human-readable action must correspond to the cryptographic effect). The corresponding invariants and their supporting security properties are formally defined in Section 4.3.

Very often, the IdP also provides auditing and maintenance services, such as directory, anomaly detection, auditing and helpdesk. An abstract eID authentication ecosystem with different stakeholders and functionality modules is visualized in Fig. 2.

4.2. Attacker model and threat taxonomy

We assume that standard cryptographic and transport protections hold. Transport layer security (TLS) protects communication between the service (RP), the identity application (User interface), and the IdP. Cryptographic primitives used for signing and verification are assumed secure, and private signing keys are not extractable from certified secure containers. The IdP infrastructure and its PKI key-management services are considered trustworthy. Under these assumptions, attacks requiring broken transport security or compromised cryptographic primitives are out of scope.

Within these bounds, we model adversarial capability across several independent dimensions. These capability categories are orthogonal; an attacker may possess one or several of them.

(C1) Social engineering and user deception. The attacker may interact directly with users through phishing pages, spoofed interfaces, fraudulent messages, or persuasive phone calls. In cross-device settings, this includes inducing victims to scan QR codes or approve requests generated under attacker-controlled sessions. Here, protocol execution may be correct, but user intent is misaligned with the authenticated session.

(C2) Network and web manipulation. The attacker may intercept, delay, replay, and reorder messages at the network layer, and may operate arbitrary web origins under their control. While TLS and signature unforgeability are assumed intact, protocol artifacts (e.g., start tokens or completion messages) may be relayed, replayed, or misapplied if freshness and binding constraints are weak.

(C3) Endpoint compromise. The attacker may gain significant control over the user endpoint (e.g., remote-access malware, UI overlays, input simulation, or screen sharing). In this case, approval actions may be observed or simulated. Protocol-level invariants may hold syntactically, yet the mapping between the human user and the cryptographic principal is no longer trustworthy.

(C4) Verifier-side and governance weaknesses. The attacker may exploit weaknesses in RP integration, middleware configuration, or lifecycle governance processes. This includes weak session/origin binding, race conditions, idempotency flaws, improper claim mapping, credential re-issuance abuse, recovery-channel manipulation, or insider bypass of controls. Authentication and signing flows may execute correctly, yet security invariants can be violated due to verifier-side errors or governance drift.

(C5) Availability disruption. The attacker may attempt to degrade system availability through volumetric traffic, excessive request initiation, polling amplification, or callback flooding. Such attacks do not violate cryptographic correctness but disrupt service continuity.

From these capability categories, we derive the following threat classes (A1–A8), which are used throughout the analysis:

- **A1 Social engineering/intent deception.** Under C1, an adversary may induce a user to initiate or approve an authentication or signing flow for an unintended purpose.
- **A2 Relay and replay.** Under C2, start tokens (e.g., QR codes or deep-link artifacts) and completion messages may be intercepted, relayed, replayed, or misapplied.
- **A3 Endpoint compromise.** Under C3, the attacker gains control over the user endpoint and may observe or simulate approval actions.

- **A4 Lifecycle abuse.** Under C4, the attacker exploits weaknesses in credential issuance, device binding, or recovery processes to obtain or rebind credentials.
- **A5 Denial of service.** Under C5, the attacker attempts to degrade service continuity through excessive request initiation, polling, or callback flooding.
- **A6 RP misbinding/verifier-side flaws.** Also derived from C4, misconfigured, buggy, or malicious RPs or middleware may introduce state inconsistencies, weak session/origin binding, improper idempotency handling, or incorrect claim mapping.
- **A7 Insider abuse.** Within C4, privileged operational roles (e.g., helpdesk or tenant administrators) may bypass lifecycle controls, override safeguards, or facilitate credential issuance under social pressure.
- **A8 Data leakage.** Under C3 or C4, identity attributes, logs, and signed artifacts may be exposed through improper logging, storage, or access control failures.

4.3. Security objectives, invariants, and supporting properties

Given the attacker capabilities defined above, secure online identification and authorization must satisfy several fundamental objectives. An identity result should be accepted only for the user who intentionally initiated a specific interaction with a specific service at a specific time. Each request that initiates a flow must be short-lived and single-use, preventing replay or reuse of protocol artifacts. The result must be bound to the exact session and service origin that created it, so that relaying or redirecting the flow to a different context is ineffective. For authorization and other high-value actions, the human-readable transaction content presented to the user must correspond exactly to the cryptographic effect of the signed result. Finally, lifecycle operations such as credential issuance, device binding, or recovery must require verification steps independent of the channel being modified, preserving identity ownership even under governance pressure.

These objectives naturally separate into two categories of security conditions. First, *security invariants* are protocol-level correctness properties that must hold for authentication and authorization to be semantically secure under the defined attacker model. Second, *supporting properties* are operational, governance, or environmental mechanisms that reinforce these invariants but are not themselves protocol-level safety guarantees. Violating an invariant compromises semantic correctness of a protocol execution; weakening a supporting property increases exposure and residual risk without necessarily altering protocol semantics.

Based on this distinction, we formalize three core invariants (I1–I3) and four supporting properties (P4–P7).

I1: Freshness. Each authentication or signing request must be uniquely identifiable, short-lived, and single-use. No identity assertion or signature result shall be accepted if it corresponds to an expired, replayed, or previously consumed request. This invariant emphasizes temporal correctness. Violation of I1 enables replay and token reuse attacks.

I2: Session and origin binding. The outcome of an authentication or signing flow must be cryptographically and logically bound to the exact client session and service origin that initiated the request. An assertion shall not be accepted if presented in a different browser session, tab, tenant context, or service origin. This invariant emphasizes contextual correctness. Violation of I2 enables relay and misbinding attacks.

I3: Dynamic linking (authorization only). For signing or authorization flows, the exact human-readable transaction content presented to the user must be cryptographically bound into the resulting signature. The RP must verify that the signed content matches the intended transaction. This invariant emphasizes semantic correctness. Violation of I3 enables semantic confusion, hidden content substitution, and authorization abuse.

P4: Lifecycle governance. Credential issuance, device binding, and recovery operations must incorporate robust governance controls, including independent verification steps, user notification mechanisms, and, where appropriate, delay-before-effect controls (e.g., cool-off period). Delay-before-effect mechanisms may be combined with out-of-band confirmation channels, such as notifications to previously bound devices or pre-registered contact points. Weak lifecycle governance enables credential abuse, unauthorized device binding, and insider-assisted attacks.

P5: Availability protection. Operational safeguards such as rate limiting, backoff mechanisms, circuit breakers, and idempotent processing must be in place to mitigate denial-of-service (DoS) conditions. Availability failures may not violate I1–I3, but can disrupt system reliability and trust.

P6: Confidentiality and data minimization. Identity attributes, session tokens, and signed artifacts must be protected against unauthorized disclosure during transport and storage. In addition, only attributes strictly necessary for the RP's purpose shall be collected and retained. Confidentiality relies on secure communication channels (e.g., TLS), secure storage, access control, and tenant isolation. Weaknesses in this property enable data leakage attacks and may facilitate impersonation or privacy violations.

P7: Endpoint integrity assumption. The guarantees provided by I1–I3 assume reasonable integrity of the user's endpoint and identity application. Under full endpoint compromise (e.g., remote access control of the device), residual risk remains even if protocol-level invariants hold. Step-up verification and anomaly detection may mitigate but cannot eliminate this risk.

Together, invariants I1–I3 protect the integrity of authentication and authorization semantics: I1 ensures temporal correctness, I2 ensures contextual correctness, and I3 ensures semantic correctness of user-approved content. These invariants constrain the logical behavior of protocol execution under the defined attacker model and determine whether a protocol run is semantically well-formed. However, they govern the correctness of execution rather than the motivations behind user actions; voluntary approval under deception may still satisfy the invariants. In contrast, the supporting properties P4–P7 govern lifecycle management, availability, confidentiality, and environmental assumptions. While invariants determine whether a protocol run is semantically correct, supporting properties determine whether identity ownership, data protection, and operational resilience remain trustworthy. Security therefore depends on both layers operating coherently.

Table 2 provides a structured mapping between the invariants (I1–I3), supporting properties (P4–P7), and the threat classes (A1–A8), illustrating how each requirement constrains specific adversarial behaviors and how these constraints are enforced through representative controls.

5. Modeling of eID schemes

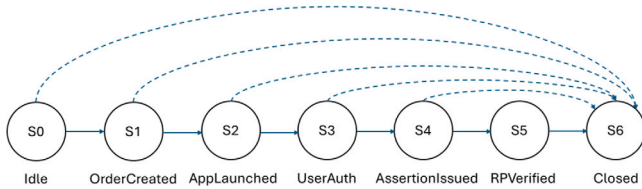
5.1. Provider-agnostic eID operation model

Building on the system model defined in Section 4, we now instantiate the two interaction patterns—same-device and cross-device—as compact state-machine flow models. These flows operationalize the responsibilities identified earlier: the relying party (RP) creates and binds requests, the user approves via the identity application, and the identity provider (IdP) issues cryptographic results that the RP verifies. The verification steps in the terminal states are structured to enforce invariants I1–I3, while supporting properties P4–P7 constrain lifecycle, availability, confidentiality, and endpoint assumptions. Threat analysis under the attacker model is applied in Section 5.2.

Table 2

Mapping of security invariants and supporting properties to threat classes and representative controls.

Index	Invariant/Property	Threats variants constrained	Representative controls
I1	Freshness	Replay and token-reuse variants of A_2	Short-lived, single-use request identifiers; explicit expiration (TTL); rejection of reused tokens; nonce uniqueness; exactly-once completion handling with idempotency keys; replay-window enforcement
I2	Session and Origin Binding	Context-confusion variants of A_2 , RP misbinding (A_6)	Binding assertion to $\{request_id, session_id, origin\}$; strict verifier-side correlation checks; tenant scoping; authenticated and fresh callbacks; rejection of cross-tab or cross-origin completions; correlation of request and completion identifiers
I3	Dynamic Linking (Authorization Only)	Intent deception (A_1), semantic substitution (A_6)	Cryptographic binding of human-readable action text and transaction digest; inclusion of text hash in signed payload; verifier-side digest comparison; clear in-app transaction display; user-verifiable fingerprint of non-visible data; refusal to grant effect if digest mismatch
P4	Lifecycle Governance	Credential re-issuance abuse (A_4), insider misuse (A_7)	Out-of-band confirmation for device binding or credential re-issuance; delay-before-effect (cool-off period); dual authorization (Shared Control); issuance alerts; recovery hardening; helpdesk verification procedures; separation of duties and audit logging
P5	Availability Protection	Denial of service (A_5)	Rate limiting; circuit breakers; exponential backoff; retry budgets; load shedding; infrastructure redundancy; authenticated and bounded polling; prevention of retry storms and callback amplification
P6	Confidentiality and Data Minimization	Data leakage (A_8)	TLS for transport; encryption at rest; minimal attribute release; strict access control; pseudonymized and tamper-evident logs; tenant isolation; short retention policies; separation of operational and analytics data
P7	Endpoint Integrity Assumption	Endpoint compromise (A_3)	Step-up verification for high-risk actions; biometric liveness checks; device binding signals; anomaly detection; transaction limits; acknowledgment of residual risk under full device compromise

**Fig. 3.** State machine for the same-device approval scenario.

5.1.1. Same-device flow

The state machine for the same-device scenario is illustrated in Fig. 3. There are seven states: S_0 Idle, S_1 OrderCreated, S_2 AppLaunched, S_3 UserAuth, S_4 AssertionIssued, S_5 RPVerified, and S_6 Closed.

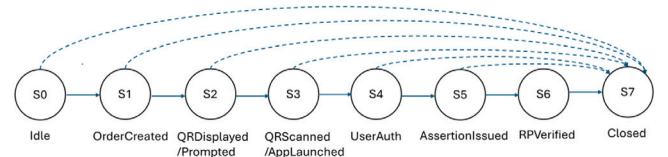
A user action (e.g., *Log in* or *Sign*) at the RP frontend triggers the backend to create a fresh authentication or signing request and record its identifier (e.g., an order reference). This identifier is bound to the current browser session and service origin (S_1). The backend returns a one-time start token to the frontend, which invokes the identity application via an operating system deep link. If valid, the app is launched (S_2).

At S_3 , the user proves presence (e.g., via PIN or biometrics). Upon approval, the IdP issues a signed identity assertion (for login) or a user-generated signature over service-supplied bytes (for signing), entering S_4 .

At S_5 , the RP verifies:

1. Signature validity and certificate chain,
2. Freshness and single-use (exactly-once consumption) of the request (I1),
3. Binding to the initiating session and origin (I2),
4. For signing flows only, dynamic linking between the human-readable transaction text and the signed digest (I3).

If verification succeeds, the flow transitions to S_6 (Closed); otherwise it terminates in failure.

**Fig. 4.** State machine for the cross-device approval scenario.

5.1.2. Cross-device flow

The cross-device flow separates the service interaction device (e.g., desktop) from the approval device (e.g., smartphone). Two variants are distinguished: local user-initiated and another-user-initiated.

Local user-initiated cross-device flow. The state machine is shown in Fig. 4. The RP creates a fresh request at S_1 and renders a short-lived, machine-readable QR code at S_2 . The QR encodes the request identifier and associated start material.

The user scans the QR code with the identity application on the approval device (S_3), performs user authentication (S_4), and the IdP issues the corresponding assertion or signature (S_5). The RP retrieves and verifies the result at S_6 , enforcing I1–I3 as described above, and transitions to S_7 .

Compared to the same-device case, the additional QR-mediated linkage introduces a distinct surface where request/session binding must be strictly enforced (I2).

Another-user-initiated cross-device flow. In this variant, the authentication request is initiated remotely (e.g., by entering a user identifier such as a personal number), and the IdP prompts the identity application directly without a locally rendered QR code. The state progression mirrors the cross-device flow, but S_2 corresponds to a prompted request rather than QR display.

While structurally similar, this variant introduces additional semantic risks because the approval is decoupled from the locally visible service context. Some ecosystems have reduced or deprecated this pattern in favor of locally initiated flows. Nevertheless, it remains relevant for modeling purposes, as it illustrates how binding (I2) and dynamic linking (I3) must operate independently of the initiation channel.

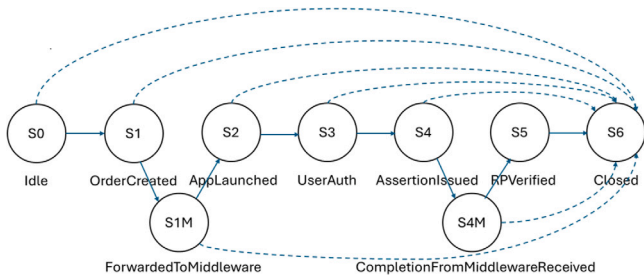


Fig. 5. State machine for the same-device approval scenario when a middleware is used.

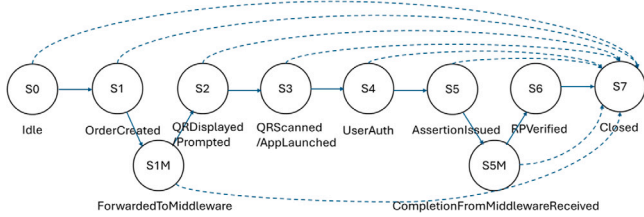


Fig. 6. State machine for the cross-device approval scenario when a middleware is used.

5.1.3. Middleware variant

An RP may integrate with the IdP through a third-party middleware or gateway. In this case, two additional logical states are introduced: forwarding the initial request to the middleware and receiving completion callbacks from it (Figs. 5 and 6).

The middleware forwards requests to the IdP and relays completion results back to the RP. Although the cryptographic core remains unchanged, the middleware introduces an additional trust boundary. The RP must continue to enforce the same verification obligations as in the direct flow (I1–I3). In addition, it must ensure that:

1. Callback messages are authenticated and originate from the expected middleware endpoint,
2. Completion handling remains idempotent and bounded to prevent amplification or duplicate processing (operational availability discipline, P5 at the RP boundary).

Middleware therefore increases integration complexity without altering the fundamental invariants of the flow.

5.1.4. Provider instantiation

Both BankID and Freja eID implement same-device and cross-device authentication and signing patterns consistent with the above abstractions. While implementation details (e.g., API endpoints, token formats, QR encoding) differ, the structural elements—request creation, user approval, assertion issuance, and verifier-side validation—remain consistent. Detailed sequence diagrams for these provider instantiations are provided in Appendix.

5.2. Scenario-based security analysis

We now analyze the operation models in light of the attacker taxonomy A1–A8 defined in Section 4.2. Table 3 summarizes the relative exposure of each scenario to these attack classes and indicates which security invariants (I1–I3) and supporting properties (P4–P7) serve as the primary mitigation mechanisms. The representative controls that operationalize these invariants and properties are summarized in Table 2. The discussion below focuses on explaining *why* a given attack class is feasible in each scenario and how enforcing the corresponding invariants and supporting properties reduces the risk.

5.2.1. Same-device identification and authorization

This scenario covers both identification (login) and authorization (signing) where the RP interaction and user approval occur on the same endpoint.

Vulnerability analysis.

1. **A1 Social engineering/intent deception.** *Login*: a user can be induced to approve an authentication they did not intend (e.g., under pressure), even when the protocol is correct. *Authorization only*: semantic deception becomes security-critical if the user-visible action text is vague or incomplete, or if decisive bytes are hidden in non-visible fields; this creates a mismatch between what the user believes they approve and what is actually authorized. *Mitigation*: I3 (authorization), with residual risk due to voluntary user approval under deception.
2. **A2 Relay and replay.** Same-device flows do not expose the QR relay surface, but replay remains possible if start tokens or completion artifacts are not strictly short-lived and single-use. *Mitigation*: I1, and (where replay causes misapplication) I2.
3. **A3 Endpoint compromise.** Remote-access malware, overlays, or input simulation can subvert user intent and UI meaning. In this case, protocol-level invariants may still hold syntactically, but the mapping between the human user and the cryptographic principal is no longer trustworthy. *Mitigation*: P7 (residual risk).
4. **A4 Lifecycle abuse.** Credential re-issuance, device (re)binding, or recovery-channel takeover can give the attacker a legitimate credential. The subsequent protocol run can satisfy I1–I3 while still authenticating the wrong principal. *Mitigation*: P4.
5. **A5 Denial of service.** RP and IdP endpoints may be subjected to resource-exhaustion or request-flooding attacks, disrupting availability while leaving cryptographic correctness intact. *Mitigation*: P5.
6. **A6 RP misbinding/verifier-side flaws.** If the RP fails to bind the returned result to the initiating session and origin, or incorrectly maps claims/roles, valid results can be misapplied. *Authorization only*: if the RP fails to verify the signed digest/action text (or accepts weakly specified text), authorization semantics can be violated even with a valid signature. *Mitigation*: I2, and I3 (authorization).
7. **A7 Insider abuse.** Insider-assisted bypass of issuance or recovery checks is possible but typically low risk; its impact is dominated by lifecycle processes rather than the same-device protocol flow. *Mitigation*: P4.
8. **A8 Data leakage.** Same-device operation itself does not require extensive data sharing, but leakage can occur via RP logs, analytics, or over-broad attribute release. *Mitigation*: P6.

Required mitigations. To reduce the above risks, the RP must enforce I1 (single-use freshness) and I2 (session/origin binding) for both login and authorization, and additionally I3 (dynamic linking) for authorization. Lifecycle risks (A4/A7) require P4, availability risks (A5) require P5, and confidentiality risks (A8) require P6. Representative controls that enforce these requirements are summarized in Table 2.

5.2.2. Cross-device identification and authorization

This scenario covers cross-device login/signing, including both local user-initiated (QR shown on the user's requesting device) and another-user-initiated (prompted) variants introduced in Section 5.1.

Vulnerability analysis.

1. **A1 Social engineering/intent deception.** *Login*: an attacker may coach the victim into approving a login they did not intend. *Authorization only*: the cross-device setting amplifies semantic deception because the approving device may not display the full RP context; if action text/digests are not dynamically linked and verified, approval can authorize unintended effects. *Mitigation*: I3 (authorization), with residual risk due to voluntary user approval under deception.

Table 3

Scenario-based exposure (High/Med/Low) and mitigating invariants/properties.

Attack	Same-device	Cross-device	Middleware	Mitigation
A1 Social engineering/intent deception	Med (login), High (sign)	Med (login), High (sign)	Med (login), High (sign)	I3 (authorization), P7
A2 Relay and replay	Low	High	High	I1, I2
A3 Endpoint compromise	Med–High	Med–High	Med–High	P7
A4 Lifecycle abuse	Med	Med	Med	P4
A5 Denial of service	Low–Med	Low–Med	Med	P5
A6 RP misbinding/verifier-side flaws	Med	High	High	I2, I3 (authorization)
A7 Insider abuse	Low	Low	Med	P4
A8 Data leakage	Low	Low	Med–High	P6

2. **A2 Relay and replay.** Cross-device flows introduce a relay surface: a victim can be induced to scan a QR/start token generated under attacker control (live relay), or stale artifacts can be replayed if tokens are long-lived. *Mitigation:* I1 (freshness) and I2 (binding).
3. **A3 Endpoint compromise.** Compromise of either device can undermine user intent (e.g., attacker controls desktop to present attacker-generated QR, or controls phone to approve). *Mitigation:* P7 (residual risk).
4. **A4 Lifecycle abuse.** Prompted initiation (another-user-initiated variant) historically increases exposure to vishing-style credential and device takeover paths, but the underlying issue remains lifecycle governance rather than protocol semantics. *Mitigation:* P4.
5. **A5 Denial of service.** Cross-device systems often include polling and callback endpoints that can be stressed by request floods. *Mitigation:* P5.
6. **A6 RP misbinding/verifier-side flaws.** Cross-device flows are especially sensitive to RP-side binding errors: if the RP does not enforce that the completion corresponds to the originating request, session, and origin, valid results can land in the wrong browser or tenant context. *Authorization only:* failure to verify the signed transaction digest/action text results in semantic misapplication. *Mitigation:* I2 and I3 (authorization).
7. **A7 Insider abuse.** As above, insider effects are primarily mediated through lifecycle and helpdesk processes rather than cross-device mechanics. *Mitigation:* P4.
8. **A8 Data leakage.** Similar to same-device flows, confidentiality risks mainly arise from RP-side logging and attribute release rather than the cross-device mechanics. *Mitigation:* P6.

Required mitigations. Cross-device security depends critically on enforcing I1 and I2: QR/start tokens must be short-lived and single-use (I1), and completion must be bound to the initiating request/session/origin (I2). For authorization, I3 is required to prevent semantic substitution. Lifecycle (P4), availability (P5), confidentiality (P6), and endpoint assumptions (P7) remain complementary and are operationalized via the representative controls in [Table 2](#).

5.2.3. Middleware-mediated identification and authorization

This scenario covers deployments where a middleware/auth gateway brokers RP requests to the IdP and mediates completion callbacks.

Vulnerability analysis.

1. **A1 Social engineering/intent deception.** Middleware does not remove intent deception: users can still be induced to approve unintended requests. *Authorization only:* if middleware truncates or rewrites action text, semantic clarity degrades even when signatures verify. *Mitigation:* I3 (authorization) with residual risk due to voluntary user approval under deception.
2. **A2 Relay and replay.** Middleware can amplify replay surfaces via retries, duplicated callbacks, or reused correlation identifiers if exactly-once semantics are not enforced end-to-end. *Mitigation:* I1 and I2.

3. **A3 Endpoint compromise.** Endpoint compromise remains scenario-independent and can invalidate user intent. *Mitigation:* P7.
4. **A4 Lifecycle abuse.** Lifecycle abuse remains possible regardless of middleware; additionally, middleware-operated support processes can become part of the lifecycle attack surface. *Mitigation:* P4.
5. **A5 Denial of service.** Middleware introduces additional endpoints (forwarding, polling, callbacks) and can create retry storms or webhook amplification. *Mitigation:* P5.
6. **A6 RP misbinding/verifier-side flaws.** Middleware introduces extra trust boundaries where binding can fail: request identifiers may be remapped, session/origin context may be dropped, and callbacks may be accepted without strict correlation to the initiating RP session. *Authorization only:* loss of the action-text/digest context breaks dynamic linking at the verifier. *Mitigation:* I2 and I3 (authorization), with I1 needed to avoid duplicate completion.
7. **A7 Insider abuse.** Middleware operators and tenant admins can influence configuration, claim mapping, and lifecycle handling, increasing insider exposure. *Mitigation:* P4.
8. **A8 Data leakage.** Middleware commonly increases logging, tracing, and data aggregation; multi-tenant storage and analytics widen the leakage surface. *Mitigation:* P6.

Required mitigations. Middleware does not change the fundamental security requirements: the RP must still be able to enforce I1 (exactly-once consumption), I2 (binding), and I3 (authorization), either locally or via a signed validation report carrying full evidence. In addition, P4–P7 become more salient due to expanded operational surfaces. Representative enforcement controls are summarized in [Table 2](#).

5.2.4. Summary

Across scenarios, the dominant risks follow a consistent pattern: semantic failures and verifier-side misbinding arise from violations of I1–I3, while lifecycle, availability, confidentiality, and endpoint risks are governed by P4–P7. [Table 3](#) provides a compact scenario-by-scenario view, and [Table 2](#) summarizes representative controls that operationalize these requirements.

6. Reported security incidents, thematic analysis, and counter-measures

6.1. Reported security incidents

It has been found that BankID has faced multiple fraud cases, primarily involving phone scams that resulted in substantial financial losses. Freja eID, on the other hand, has encountered issues mainly related to the circulation of fake apps used for identity misuse. Neither service has experienced major system security breaches; reported incidents have been limited to fraud and misuse targeting end-users. The following cases provide evidence of the types of fraud and misuse identified. Each incident is then mapped to our attacker types A_1 to A_8 identified in [Section 4.2](#).

- “Offer became purchase” (Kristianstad, 2025) — tags: [A_1 social engineering/intent deception], possibly [A_6 verifier-side flaws]. A 78-year-old asked for a solar-panel quote and was told to “sign with BankID” to get an offer; her “offer” approval was treated as a binding purchase (Kristianstadsbladet, 2025b). Sweden’s Consumer Agency reminded people to pause and only approve with BankID when they clearly understand they are entering into an agreement (Kristianstadsbladet, 2025a). This incident primarily illustrates intent deception (A_1), but it can also expose a technical flow failure at the RP (A_6). If the merchant initiated a signature order while presenting only vague in-app text (for example “confirm offer”) and placed the contract bytes solely in non-visible data or in a hyperlinked lengthy document that the consumer ignored, the result is a cryptographically valid signature on content the signer did not meaningfully review. That is not a break in BankID’s cryptography; it is a misuse of the signature interface that collapses “get a quote” and “sign a contract” into one step without adequate, human-readable linking.
- BankID denial-of-service outage (April 23–24, 2025) — tags: [A_5 denial of service]. BankID experienced several hours of unavailability due to a distributed denial-of-service attack. Press statements stressed no data was compromised, but critical services (bank logins, Swish, health portals) were impacted until shortly before midnight in Sweden, with some residual impact for users abroad the next morning (BankID, 2025c; Aftonbladet, 2025; SVT, 2025). This squarely matches A_5 in our attacker model and validates our earlier availability assumptions: even if cryptography and binding are intact, availability can still be a point of failure.
- Freja eID “fake app” (2023–2024) — tags: [A_1 social engineering/intent deception] and [A_6 RP misbinding/verifier-side flaws]. Retailers and trade groups reported counterfeit apps that mimic Freja’s digital ID card, with altered dates or photos, circulating among youth. The apps were used to purchase age-restricted items such as alcohol or tobacco (Svensk Handel, 2024). This is not a breach of Freja’s systems; it is a spoofed presentation accepted by human checkers or by stores without robust verification procedures—squarely A_1 (spoofed UI) plus A_6 (RP verification weaknesses). The right control is merchant-side verification of online status or cryptographic proofs, not trusting a look-alike screen.
- Rental scams (Uppsala, 2023) — tags: [A_1 social engineering], [A_2 relay], [A_4 lifecycle abuse]. Local reporting describes students in Uppsala being defrauded after responding to a rental advertisement. Victims were induced to scan a QR code and authenticate using BankID under the pretext of a credit check. Subsequently, they were persuaded to authorize the issuance of a new BankID credential, after being told that the initial authentication had failed (SVT, 2024). The first step reflects intent deception (A_1) combined with relay (A_2), while the second step constitutes confirmed lifecycle abuse (A_4), as credential issuance was authorized under attacker manipulation.
- BankID vishing cases (2018 conviction; 2022 Supreme Court ruling) — tags: [A_1 social engineering]. Swedish courts have repeatedly dealt with BankID vishing incidents. In 2018, a group was convicted for phone scams that induced victims to authenticate and approve BankID actions, enabling unauthorized account access and transfers (Radio Sweden, 2018). In 2022, the Supreme Court (NJA 2022 s. 522) held that a victim deceived by a fake “bank” call acted grossly negligent but not “particularly reprehensible”, limiting liability and ordering reimbursement (The Supreme Court, Sweden, 2022). These cases demonstrate the effectiveness of A_1 social-engineering campaigns in exploiting legitimate authentication and authorization flows.
- BankID phone scam case (2018) — tags: [A_1 social engineering]. Media reports from 2018 describe elderly victims deceived by callers spoofing a bank’s phone number and instructing them

to log in with BankID, which then enabled account access and unauthorized withdrawals (Aftonbladet, 2018b,a). The mechanics reflect classic A_1 social engineering: victims completed legitimate authentication and, in some cases, authorized transactions under deception. No cryptographic weakness was reported; the fraud relied on manipulation of valid authentication and authorization flows.

6.2. Thematic analysis

Across these cases, a recurring theme is **misaligned intent at approval time**. Under this theme, the dominant code is **intent deception**: victims are rushed or misled into approving something different from what they believe (A_1) (BankID phone scam case (Aftonbladet, 2018a,b), BankID vishing cases (Radio Sweden, 2018), “Offer became purchase” (Kristianstadsbladet, 2025a,b)). This theme is amplified by two supporting codes: **credential lifecycle abuse** — tricking a victim into issuing a new credential that the adversary controls (A_4) (Rental scams (SVT, 2024)) — and **misconfigured or malicious RP** (A_6), where a merchant or site accepts what looks right (Freja eID “fake app” (Svensk Handel, 2024)), or a consumer approves what looks right (“Offer became purchase” (Kristianstadsbladet, 2025a,b)), without verifying what is right.

Availability risk (A_5) appears as a separate, system-level theme: even when cryptography and bindings hold, the service can be made temporarily unusable (BankID denial-of-service outage (BankID, 2025c; Aftonbladet, 2025; SVT, 2025)).

Notably, none of these reports indicate a break of BankID or Freja’s core cryptography; the harm flows from social engineering, flow design, and verification practice (Freja eID “fake app” (Svensk Handel, 2024), BankID denial-of-service outage (SVT, 2025)).

6.3. Incident-informed countermeasures

At the thematic level, the incidents cluster around **misaligned intent at approval time**. The dominant pattern is **intent deception** (A_1), sometimes combined with lifecycle abuse (A_4) or verifier-side flaws (A_6). Countermeasures that strengthen semantic transparency and verifier discipline—explicit action text cryptographically bound into authorization results (I3), strict session/origin binding (I2), and hardened lifecycle governance for credential changes (P4), including delay-before-effect mechanisms and independent confirmation — materially reduce escalation paths, although they cannot eliminate deception when users (due to user awareness issue) voluntarily approve attacker-directed actions.

Availability (A_5) appears as a separate system-level theme and requires dedicated operational resilience measures (P5).

Below we present countermeasures tailored to the reported incidents.

6.3.1. “Offer became purchase” (Kristianstad, 2025)

The merchant invoked a signing flow but framed it as “just identification”, creating intent confusion (A_1) and a verifier-side design flaw (A_6). The user completed a valid signing ceremony; freshness (I1) and session/origin binding (I2) were satisfied, and a cryptographically valid signature was produced. The failure arose at the semantic layer: the human-readable action text did not adequately represent the contractual effect of the signed content. Thus, invariant I3 (dynamic linking) was not meaningfully satisfied at the relying party.

This incident type can affect both same-device and cross-device signing flows.

For countermeasures, identification and signature must remain distinct ceremonies. When a signature flow is invoked, the app should display a clear, plain-language statement of the commitment together with a concise digest or summary of any underlying document. That text (and associated document digest) must be cryptographically bound into the signed artifact and verified before granting effect, thereby enforcing I3.

6.3.2. BankID denial-of-service outage (April 23–24, 2025)

This incident was availability-centric (A_5) and operationally affected all scenarios. Volumetric traffic disrupted order creation and result collection endpoints, impairing transitions in the operation model without violating cryptographic correctness. Protocol-level invariants (I1–I3) were not violated; rather, the supporting availability property (P5) was stressed under load.

For countermeasures, RPs should ensure that their integrations do not amplify traffic or fail unsafely under stress. Polling intervals and timeouts should be conservative, callbacks must be authenticated and fresh, and completion handling must remain idempotent and exactly-once so that retries and duplicates do not cascade. While such measures cannot prevent a platform-level denial of service, they enforce P5 locally and maintain stable verifier-side behavior during outages.

6.3.3. Freja eID “fake app” (2023–2024)

Merchants relied on visual inspection of a screen and accepted look-alike applications as proof of identity, bypassing backend verification. No protocol execution occurred at the verifier side; the cryptographic validation step in the operation model (result verification at $S_5 \rightarrow S_6$ in Fig. 3 or $S_6 \rightarrow S_7$ in Fig. 4) was omitted. This corresponds to a verifier-side flaw (A_6). Protocol-level invariants (I1–I3) were not violated during execution; rather, they were never enforced.

Although this incident involves face-to-face presentation of a digital ID and falls outside the online flow scenarios, the verifier duty remains analogous.

For countermeasures, merchants must require online or backend verification of the digital ID (e.g., scanning and validating the animated code or performing a server-side check), rather than relying on visual inspection. The relying party must enforce cryptographic validation of the provider-issued artifact and its bindings, consistent with I2 and (where applicable) I3.

6.3.4. Rental scams (Uppsala, 2023)

Victims were induced to scan a QR code and authenticate under a deceptive pretext (A_1/A_2), and were subsequently persuaded to authorize issuance of a new BankID credential, constituting confirmed lifecycle abuse (A_4). While replay and context-confusion variants of A_2 can be constrained by freshness (I1) and strict session/origin binding (I2), the decisive failure in this case lay in lifecycle governance (P4).

Countermeasures therefore include animated, short-lived QR codes to reduce replay exposure, strict binding of {request id, session, origin} to prevent context confusion, and—critically—stronger lifecycle protections such as delay-before-effect mechanisms and independent confirmation for credential issuance.

6.3.5. BankID vishing cases (2018 conviction; 2022 Supreme Court ruling)

Victims were socially engineered (A_1) into completing legitimate authentication and, in many instances, signing payment transactions under attacker guidance. The protocol-level invariants governing authentication (I1 and I2) were satisfied, and any signed transactions followed the normal dynamic-linking procedure (I3). The attacker exploited the victim’s valid approvals rather than any cryptographic flaw.

This incident type can affect all online scenarios, as both authentication and authorization flows may be manipulated under social pressure.

For countermeasures, maintain clear and explicit transaction presentation in authorization flows (I3), require unambiguous action text for high-risk operations, and apply risk-based step-up verification where appropriate (e.g. for elderly). While these measures cannot eliminate social engineering, they limit the scope and impact of attacker-driven misuse of legitimate authentication and signing.

6.3.6. BankID phone scam case (2018)

The most parsimonious explanation is a social-engineering (vishing) attack in which the victim was persuaded to authenticate using BankID during a phone call, enabling the attacker to access the victim’s bank session and execute unauthorized transactions. The mechanism reflects an A_1 (social engineering) attack. Whether the authentication was initiated by the victim or triggered remotely is immaterial; the decisive factor was that the victim completed a legitimate authentication under deception.

This incident can affect authentication flows in any device pattern, and if payment authorization is involved, it also implicates signing flows.

For countermeasures, any action with financial or authorization impact should be treated as an explicit signing task rather than a mere login. The app must present a short, plain-language action text (e.g., amount, counterparty, purpose), bind that text into the signed artifact, and require the RP to verify it before execution (I3). In parallel, unsolicited or remotely triggered login requests should be restricted or carefully audited, and customers should be instructed never to authenticate or approve actions at someone else’s request. These measures limit the attacker’s leverage by ensuring that authority arises only through explicit, user-visible, transaction-bound approval.

7. Provider security controls in BankID and Freja eID: Features and evaluation

7.1. Built-in controls (feature summary)

7.1.1. Features in BankID

In the following, we present the built-in security controls that can be found on BankID website (Finansiell ID-Teknik BID AB, 2025a).

Secure Start (mandatory since 1 May 2024) forces safe initiation paths: on the same device the app must auto-launch; on cross-device the desktop must use an animated, short-lived QR code. Static codes and manual personal number (or social security number) entry to start a flow are no longer allowed. For high-risk cases, “Extra Identity Verification” can require a real-time passport or national identity card scan (chip read over near-field communication (NFC)) inside the app. A “Risk Indication” service returns a low/medium/high score alongside normal results, based on signals such as the user’s internet address, device or browser data, launch method, and device identifiers (the exact model is undisclosed). User-facing protections include showing the RP’s name and the action, education on safe use, the ability to block BankID on suspicion, and alerts users when a new BankID credential is issued on their personal numbers (or social security numbers).

7.1.2. Features in Freja eID

In the following, we present the built-in security controls that can be found on Freja eID website (Freja eID Group AB, 2025).

For high-risk actions (or spot checks), Freja can require a live selfie that is matched by facial recognition against the verified enrollment photo; only a successful match allows the action to proceed. Users can add “Shared Control” (a trusted co-approver must consent) and can disable entire categories of services in the app so requests in those categories are auto-rejected. Freja eID Plus offers “ID Protection”, which monitors population-register address changes and alerts the user immediately (it does not block the change). For in-person checks, the app shows a digital identity card with a QR code that verifiers can scan to validate online in real time. With explicit per-use consent, Freja can share the mobile device’s internet address with an RP during an identification or signature.

7.2. Security evaluation

We evaluate BankID and Freja eID through two lenses. First, we assess coverage against the attacker types ($A_1 - A_8$) defined in Section 4.2, i.e., what the threat model predicts in principle. Second, we evaluate against the incidents in Section 6, i.e., what happened in practice.

7.2.1. Evaluation by attacker taxonomy

Against intent deception and social engineering (A_1). BankID's in-app display of the RP's name and the action, combined with Secure Start, closes common "cheap starts" (static codes, manual number entry) that scammers exploited. That is effective baseline hygiene but does not eliminate persuasion /social engineering attacks; the strongest protection remains using the signing flow with clear, human-readable purpose text for any binding action and having the user verify that text. Freja's Shared Control and optional live face checks add meaningful friction in high-risk contexts and can defeat some coerced approvals.

Against replay/relay and misbinding (A_2). BankID's animated, short-lived QR codes materially reduce replay windows. They are adequate only if the RP enforces strict binding of the returned result to the original request, session, and site origin — something the IdP cannot guarantee on its own. Freja's online verification of the digital identity card is a strong answer to the "fake-app screen" problem in retail (Svensk Handel, 2024) if merchants actually scan rather than eyeball — process, not crypto, is the limiting factor.

Against on-device remote control (A_3). Neither system can fully neutralize a compromised phone or a live screen-share. BankID's ordinary biometrics and Freja's optional live face improve assurance but do not stop a determined, real-time coercion. These remain residual risks.

Against lifecycle abuse (A_4). BankID's issuance alerts and the ability to block a credential are good detective and responsive controls; coupled with Extra Identity Verification, they raise the bar for fraudulent re-issuance. Freja's address-change alert helps catch downstream identity takeover but does not directly govern credential issuance or device binding. In both ecosystems, cool-off period and out-of-band confirmations for adding devices or re-issuing credentials remain essential policies.

Against denial of service (A_5). The presented features above are largely about correctness and fraud; they do not directly address availability hardening. Resilience still hinges on RP and integrator (middleware) choices (short timeouts, backoff, rate limits, circuit breakers, exactly-once processing), which should be layered on top.

Against RP integration gaps (A_6). Secure Start is a strong ecosystem-wide win: it forces safer initiation and removes error-prone patterns. BankID's Risk Indication can help triage, but its opaque scoring means RPs must treat it as a hint, not a decision oracle. Freja's verifier-scan for the digital identity card is exactly the right control for retail — if merchants use it. Across both, adequacy depends on RPs upholding strict session /origin binding and verifying the hash of the purpose text before executing sensitive actions.

Against insider abuse (A_7). The presented features help, but only at the edges. We need more organizational controls like dual authorization and auditing. Insider abuses are mostly about people with privileged process access — or staff who can be persuaded to bypass checks — so IdP-side features only partially cover them. For BankID, "Extra identity verification" (passport/ NFC scan in-app) is meaningful because it forces real user presence for high-risk actions, which a back-office insider cannot fake without the user. For Freja eID, the optional live-face step also enforces user presence and blocks many insider-only attempts. Shared Control (co-signer) is the strongest insider counter here: it creates true dual control at the user side, so a single insider cannot complete a critical action.

Privacy and data minimization (A_8). Most controls align with minimization, but Freja's optional sharing of the device's internet address should be used sparingly and only when it materially reduces risk. Both ecosystems benefit from RPs requesting the least data needed and keeping logs pseudonymized with short retention.

7.2.2. Evaluation against reported incidents — are they still possible?

"Offer became purchase" (Kristianstad, 2025). *Attack mechanism:* The RP initiated a signing flow rather than a pure identification flow. The user completed the transition UserAuth $\rightarrow$ AssertionIssued ($S_3 \rightarrow S_4$ in Fig. 3 or $S_4 \rightarrow S_5$ in Fig. 4) and produced a cryptographically valid signature over service-supplied bytes. While freshness (I1) and session/origin binding (I2) were satisfied, the visible action text presented in the app was ambiguous, and decisive contractual content was embedded in non-visible data or in another document that the user did not read carefully. Thus, the cryptographic artifact bound the contract content, even though the user believed they were merely confirming an offer. This corresponds to an A_1/A_6 attack, reflecting a failure to meaningfully satisfy invariant I3 (dynamic linking) at the RP, as the human-readable action text did not adequately represent the cryptographic effect of the signed content.

Residual feasibility: This attack remains possible, although policy and UX improvements can reduce its likelihood.

This is because Secure Start constrains how a session starts (deep-link or animated QR), not what the text in the app says. If an RP initiates a signature with vague/ambiguous user visible text for purpose description and hides the decisive bytes in non-visible data or in another lengthy document, a rashy user can still be deceived into approving a binding signature. Risk Indication will not reliably catch a local, legitimate device on a normal network.

Overall, A_1/A_6 remains a residual risk. The fix is verifier-side (clear in-app text, digest checks); IdP features alone do not eliminate it.

BankID denial-of-service outage (Apr 2025). *Attack mechanism:* The attacker generated volumetric traffic targeting IdP endpoints responsible for order creation or result collection. This disrupted transitions such as OrderCreated $\rightarrow$ AppLaunched/QRDisplayed ($S_1 \rightarrow S_2$ in Fig. 3, 4) or AssertionIssued $\rightarrow$ RPVerified ($S_4 \rightarrow S_5$ in Fig. 3, and $S_5 \rightarrow S_6$ in Fig. 4), without violating cryptographic correctness. This corresponds to an A_5 (denial of service) attack and reflects insufficient availability protection (P5) under the observed load conditions.

Residual feasibility: This attack remains possible.

This is because fraud-prevention features target misuse and deception, not volumetric overload. Availability hardening is primarily an infrastructure concern.

Overall, fraud controls like Secure Start may stop some illegitimate approval requests, but have little effect on overall A_5 exposure; RP-side resilience (timeouts/backoff/idempotency) is needed in addition to IdP-side infrastructure hardening.

Freja eID "fake app" (2023–2024). *Attack mechanism:* The attacker presented a spoofed application interface to merchants, bypassing backend verification entirely. No state-machine execution occurred; instead, the verifier failed to perform the $S_5 \rightarrow S_6$ (Fig. 3) or $S_6 \rightarrow S_7$ (Fig. 4) cryptographic validation step and relied solely on visual inspection. This corresponds to an A_6 (RP misbinding /verifier-side flaw) attack. The protocol invariants I2 and I3 were not violated during execution; rather, they were never enforced because the verifier bypassed the cryptographic validation step entirely.

Residual feasibility: This attack remains possible, if merchants keep eyeballing screens.

Though Freja's digital ID card is online-verifiable (scan and verify). If merchants skip verification and rely on screenshots/look-alike, IdP-side cryptographic controls cannot compensate.

Overall, A_6 -style verifier failure continue to exist in physical context, and this can only be solved by mandatory online verification at the merchant.

Rental scams (2023). *Attack mechanism:* The attacker initiated an authentication request under their own browser session ($S_0 \rightarrow S_1$ in Fig. 4) and induced the victim to scan the corresponding QR code ($S_2 \rightarrow S_3$ in Fig. 4) via a screen relay/screenshot. The victim completed $S_3 \rightarrow S_4$ (Fig. 4) on their device, producing a valid assertion bound to the

attacker's controlled session. Session/origin binding (I2) was satisfied; freshness (I1) may also hold in a live relay setting. The first phase therefore reflects A_1 (social engineering) combined with A_2 (relay). While I1 and I2 constrain replay and misbinding variants of A_2 , they do not prevent live relay when a victim voluntarily authenticates an attacker-controlled session.

In the reported Uppsala cases, the attacker then escalated by persuading the victim to *authorize issuance of a new BankID credential* after claiming the initial step had “failed”. This second phase constitutes confirmed A_4 (lifecycle abuse): a sensitive lifecycle operation was approved under deception. The signing step may still satisfy the protocol mechanics of dynamic linking (I3) in a cryptographic sense, but semantic alignment between the user's understanding and the lifecycle consequence was lost; lifecycle governance protections (P4)—such as stronger step-up, independent out-of-band confirmation, and delay-before-effect—were therefore insufficient. Overall, the incident illustrates that protocol-level correctness in authentication (I1/I2) does not by itself prevent credential takeover when lifecycle operations are socially engineered.

Residual feasibility: The risk of this type of attack is reduced in some variants, but not eliminated. Measures that harden authentication flows increase friction against replay (A_2), yet lifecycle abuse (A_4) remains feasible under social engineering (A_1).

BankID's mandatory Secure Start since 2024 enforces animated and short-TTL QR codes, which block static replay of QR screenshots and make relay-based authentication scams more difficult. However, live relay remains possible if a victim cooperates in scanning an attacker-generated QR code. In such cases, freshness (I1) and session/origin binding (I2) are satisfied, as the victim legitimately authenticates the attacker's session. The decisive escalation in the reported case occurred in the subsequent lifecycle phase: the victim was persuaded to authorize issuance of a new BankID credential. This constitutes lifecycle abuse (A_4), which is not prevented by I1 or I2 and instead depends on the strength of lifecycle governance controls (P4). Risk Indication may provide warning signals, but it cannot prevent voluntary approval of either authentication or issuance steps.

Overall, static replay (A_2) exposure is reduced by Secure Start, but social-engineered authentication (A_1) and lifecycle abuse (A_4) remain residual risks. Authentication invariants (I1/I2) ensure protocol correctness, yet credential takeover can still occur if lifecycle operations are authorized under deception. Strengthening P4—through delay-before-effect mechanisms, independent confirmations, and stricter issuance procedures—is therefore critical.

BankID vishing cases (2018; 2022). *Attack mechanism:* In these cases, attackers impersonated bank security staff and persuaded victims to use BankID to log into their bank accounts, thereby granting the gang access. The victims completed legitimate authentication and, in many instances, approved subsequent payment transactions under attacker guidance. The resulting assertion or signature was cryptographically valid and correctly bound to the session. Freshness (I1) and session/origin binding (I2) were satisfied, and any signed transaction followed the normal dynamic-linking procedure (I3) of the platform. The fraud arose from intent deception (A_1), not from protocol misbinding or replay.

Residual feasibility: The risk of this attack is reduced, but not eliminated.

Mandatory Secure Start since 2024 prevents attackers from initiating authentication solely by entering a victim's personal number and constrains replay variants of A_2 through enforcement of I1. However, Secure Start does not prevent a victim from voluntarily authenticating or signing transactions under social pressure. While dynamic linking (I3) ensures that transaction details are displayed and cryptographically bound to the signature, it cannot prevent fraud when a victim knowingly approves the displayed transaction under deception.

Overall, exposure to unsolicited authentication and replay attacks (A_2) is substantially reduced. Nevertheless, social-engineered misuse

of legitimate authentication and authorization (A_1) remains a residual risk. The case illustrates that protocol invariants (I1–I3) ensure correct execution but cannot alone eliminate fraud driven by user deception.

BankID phone scam case (2018). *Attack mechanism:* This incident mirrors the vishing pattern described above. An attacker impersonating bank staff persuaded the victim to authenticate using BankID during a phone call. The victim completed a legitimate authentication (and in some cases payment authorization), producing cryptographically valid assertions and signatures. Freshness (I1), session/origin binding (I2), and dynamic linking (I3) were satisfied. The fraud resulted from intent deception (A_1), not from protocol misbinding or replay.

Residual feasibility: This attack remains possible, and the assessment is analogous to the vishing cases above.

As discussed above, Secure Start reduces unsolicited authentication and replay-style variants, but cannot prevent voluntary authentication or signing under social pressure.

Overall, similar to the vishing case, exposure to replay-based attacks is reduced, yet social-engineered misuse of valid authentication and authorization (A_1) remains feasible despite correct protocol execution.

Summary. In conclusion, IdP-side controls narrow initiation vectors (e.g., Secure Start), increase friction in sensitive flows (e.g., document/NFC verification, biometrics, Shared Control), and improve anomaly detection (Risk Indication, alerts). These measures primarily reinforce freshness (I1) and reduce replay-style variants of A_2 , and may indirectly support binding discipline. However, they do not by themselves guarantee correct session/origin binding (I2) or semantic alignment in authorization (I3), nor do they eliminate incidents driven by intent deception (A_1), verifier-side binding failures (A_6), lifecycle abuse (A_4), or availability disruption (A_5).

Protocol-level invariants—freshness (I1), session/origin binding (I2), and dynamic linking (I3)—ensure semantically correct execution of authentication and authorization flows. Residual risk persists when users voluntarily approve attacker-directed actions, or when lifecycle governance (P4) and availability protection (P5) are insufficiently hardened. Effective defense therefore requires strict RP-side enforcement of I1–I3, disciplined lifecycle governance (P4), and robust operational resilience measures (P5).

8. Discussion

8.1. Contributions revisited

This article developed a structured, provider-agnostic framework for reasoning about online eID security. We first defined an explicit system model and attacker model (Section 4), from which we derived protocol-level invariants and supporting properties (Section 4.3). The system model was then instantiated as a provider-agnostic operation model expressed through abstract state machines capturing same-device and cross-device flows, including a middleware variant (Section 5). The attacker model informed both the scenario-based security analysis (Section 5.2) and the evaluation of documented real-world incidents (Sections 6, 7.2.2). Evaluating the operation model against the defined invariants—freshness (I1), strict session/origin binding (I2), and dynamic linking for authorization (I3)—clarifies verifier duties in both identification and signing flows and makes explicit which checks must remain enforced at the relying party.

Modeling middleware explicitly revealed additional trust boundaries where binding, callback validation, and idempotency can fail. This sharpened the distinction between cryptographic correctness and integration discipline, and identified concrete RP-side obligations even when orchestration is outsourced.

Evaluation against documented incidents (Sections 6, 7.2.2) demonstrated that real-world failures rarely stem from broken cryptographic primitives. Instead, dominant causes include intent deception (A_1), verifier-side flaws (A_6), lifecycle abuse (A_4), and availability disruption

(A₅). The invariant-property framework explains how these failures arise—whether through semantic misalignment, governance weakness, or operational fragility—despite correct protocol execution.

Analysis of provider-side features (Section 7) further showed that IdP enhancements such as Secure Start, risk indication, and step-up verification narrow attack surfaces but do not eliminate deception or integration failures. End-to-end security therefore depends on strict RP-side enforcement of I1–I3, disciplined lifecycle governance (P4), and operational resilience (P5).

Overall, the novelty of this work lies not in proposing new attack types, but in structuring known threats within a unified invariant-based operational framework that links attacker capabilities, protocol semantics, governance properties, and empirical incidents. This provides a reusable analytical foundation for reasoning about end-to-end eID security across providers and architectures.

8.2. Generalizability of the proposed security model

The proposed state-machine abstraction does not depend on vendor-specific APIs or national regulatory context. Instead, it captures the authentication lifecycle common to PKI-based eID systems—whether implemented via smartcards, SIM-based solutions, or mobile applications—comprising request initiation, user key-possession proof, assertion issuance, and verifier-side validation. As demonstrated in Section 2.4, similar architectural patterns exist in German eID (nPA), Estonian eID, Belgian eID, and other eIDAS-notified schemes. Consequently, the invariants of freshness (I1), strict session/origin binding (I2), and dynamic linking of human-readable authorization text (I3) apply equally to these systems with minimal adaptation at the message or transport layer. Even when transport protocols, user-interface patterns, or enrollment procedures differ, the dimensions of temporal, contextual, and semantic correctness remain applicable.

The model also extends to federated and multi-provider identity ecosystems under eIDAS 2.0, including wallet-based architectures. Although the technical representation of assertions may vary (e.g., SAML, OpenID Connect, or verifiable credentials), relying parties must still enforce freshness, contextual binding, and semantic integrity of approved actions. Likewise, cryptographic agility—such as migration to post-quantum signature schemes—does not alter the invariant structure, since I1–I3 constrain how results are generated, bound, and verified rather than which cryptographic primitives are employed.

Systems relying solely on OTP-based authentication (e.g., password + SMS) can also be described within the lifecycle model at an abstract level. However, because they lack user-generated digital signatures, they cannot natively enforce dynamic linking (I3) for transaction content. This distinction highlights a structural advantage of certificate-based architectures in high-value authorization contexts.

In this sense, BankID and Freja eID are not treated as isolated national case studies, but as representative instances of a broader class of eID ecosystems. The invariant-based framework therefore provides a reusable analytical tool for evaluating end-to-end security properties across PKI-enabled national and cross-border digital identity deployments.

8.3. Relation to formal protocol analysis

A substantial body of prior work has analyzed authentication protocols using formal methods, often under the Dolev–Yao symbolic attacker model. Such approaches model message exchange and cryptographic operations abstractly and aim to prove properties such as secrecy, authentication correspondence, and resistance to replay or man-in-the-middle attacks. Recent examples include formal analyses of authentication and authorization protocols using symbolic verification frameworks and automated tools (e.g., (Jacomme and Kremer, 2021; Sciarretta et al., 2020; Wang, 2026)), where protocol message flows are analyzed under classical or extended Dolev–Yao adversary models.

Our work differs in abstraction level and objective. Rather than formally verifying cryptographic message flows, we model the end-to-end authentication lifecycle—including user approval semantics, session binding, RP integration, and lifecycle governance—using abstract state machines and invariant properties. This enables us to reason about failures that arise not from broken cryptography but from misbinding, lifecycle abuse, or semantic misalignment between user intent and authorization effect. While symbolic analyses focus primarily on message-level correctness under well-defined adversary models, our framework emphasizes integration semantics, lifecycle processes, and user-intent alignment, which are typically abstracted away from protocol trace verification.

In this sense, the proposed framework is complementary to symbolic protocol verification: it assumes cryptographic primitives are sound and instead concentrates on architecture-level and deployment-level invariants. A complete formalization of the state machines and invariants in a symbolic or computational model would be an interesting direction for future work, but is beyond the scope of the present study.

8.4. Limitations and threats to validity

First, the study relies on public documentation and reports. We did not have access to provider-internal telemetry, incident forensics, or confidential integration guidance, and we did not instrument live systems. As a result, some claims (for example algorithm choices, precise risk-scoring inputs, operational thresholds) are treated abstractly, and we evaluate effectiveness at the level of mechanisms and invariants rather than measured detection rates.

Second, our state-machine model is intentionally minimalist. It captures control-flow and security-relevant bindings, but it abstracts away user-interface nuance, micro-timing, and recovery paths that may matter in edge cases. Different integrators and middleware vendors can introduce additional states or retries; we represent these only insofar as they affect the invariants (freshness, binding, dynamic linking).

Third, we do not claim comprehensive coverage of all operational modes. Telephone identification, in-person checks without online scanning, attribute-sharing workflows, and specialized enterprise flows are discussed only as reductions to the two canonical journeys. This keeps the analysis tractable but leaves room for context-specific considerations (for example, offline verification policies in retail).

Fourth, the article assumes sound cryptography and transport security (for example, correct certificate validation and TLS configuration) and does not model powerful adversaries able to compromise hardware roots or operating system trust anchors. Likewise, our availability discussion is conceptual; we did not conduct network-level measurements or load testing to quantify resilience under denial-of-service.

Finally, human factors are central to the dominant threat (intent deception), yet we did not run user studies to test comprehension of action texts, susceptibility under pressure, or the practical trade-offs of step-up policies. Our recommendations for wording, dynamic linking, and step-up are theory- and incident-informed, not experimentally validated in this work.

8.5. Implications and future work

For practitioners, the results prioritize where to spend effort: default to the signing flow with clear, bound text for binding actions; keep verification at the RP (signature, session/origin binding, action-text hash); treat middleware boundaries as security-critical interfaces with authenticated, fresh, and exactly-once events; and harden lifecycle changes with cool-off period and out-of-band confirmations. For retail scenarios, require online verification of digital IDs instead of trusting look-alike screens.

Future work should add empirical depth: conformance tests for integrators and middleware against the state machines; measurements of QR lifetimes, drift rejection, and callback hygiene in the wild; and user

studies on the clarity and placement of transaction text. Formal specification and model checking of the flows could complement our work. Finally, longitudinal studies of incident trends would test whether the proposed countermeasures measurably reduce the dominant failure mode — misaligned intent at approval time — without unacceptable friction for end users.

Beyond explaining current systems, the proposed invariant-based framework provides concrete guidance for future eID designs. The invariants of freshness, session/origin binding, and dynamic linking align with eIDAS 2.0 requirements for transaction-specific user consent and verifier-side validation discipline. Because these invariants constrain how authentication and authorization results are generated, bound, and verified—rather than prescribing specific cryptographic primitives—they remain applicable under cryptographic agility, including migration to post-quantum signature schemes. This abstraction allows system designers to reason about end-to-end security properties independently of evolving algorithm choices.

8.6. Lessons learned

Across the systems explicitly analyzed in this paper, i.e. BankID and Freja eID, and in prior studies of Denmark's MitID (Kingo and Aranha, 2023) and the Estonian ID-card (Parsovs, 2020), major incidents have rarely resulted from broken cryptographic primitives. Instead, reported failures arose from intent deception, relay and misbinding, lifecycle weaknesses, or verifier-side integration errors (see Sections 6, 7.2.2). This pattern suggests that end-to-end security depends as much on disciplined integration and governance as on the choice of cryptographic algorithms.

A recurring lesson is that verifier-side enforcement is decisive. In several Swedish cases (Sections 6, 7.2.2), valid cryptographic results were produced, yet harm occurred because session binding or transaction semantics were not strictly enforced at the relying party. Identity providers can supply secure primitives, but relying parties must correctly bind results to the initiating session and origin, and—where authorization is involved—ensure that user-approved content matches the cryptographic effect (Section 5).

Lifecycle governance emerges as a first-class concern. Real-world incidents (Sections 6, 7.2.2) involving device re-binding, recovery, or credential issuance demonstrate that authentication protocols may execute correctly while identity ownership has already been subverted. Delay-before-effect mechanisms and independent out-of-band confirmations therefore serve not as substitutes for cryptography, but as controls that reduce the impact of governance weaknesses.

Cross-device convenience increases semantic risk. As shown in the rental-scam example (Sections 6, 7.2.2), separating request initiation and approval enlarges the opportunity for intent deception and context confusion. Clear transaction context, strict result binding and freshness are therefore essential safeguards in such patterns.

More broadly, modeling security at the level of the end-to-end operation lifecycle (Section 5) reveals how failures arise despite correct message-level cryptography. By explicitly distinguishing protocol-level invariants from supporting governance properties (Section 4.3), the model clarifies which failures stem from binding and semantic errors and which stem from lifecycle, availability, or operational weaknesses. This separation helps identify where defenses must be strengthened in practice.

An additional lesson concerns the limits of technical safeguards against intent deception. In several cases, including the BankID vishing and phone scam incidents (Sections 6, 7.2.2), authentication and signing protocols executed correctly (I1–I3), yet fraud succeeded because victims voluntarily approved attacker-directed actions. This underscores that user-awareness measures and clear communication about legitimate usage patterns are essential complements to protocol-level guarantees. While invariants constrain technical attack surfaces, they cannot fully eliminate deception-driven misuse.

9. Conclusion

This article develops a provider-agnostic security model for online electronic identity and applies it to BankID and Freja eID. We formalize the two canonical user journeys — same-device and cross-device — and their two purposes, identification (login) and signature (authorization), as compact state machines (with and without middleware). From these models we derive three security invariants that govern correctness in practice: freshness of challenges and results, binding of each result to the initiating session and site origin, and dynamic linking of a short, human-readable action text.

Using this framework, we evaluate BankID and Freja eID across attacker taxonomy and cross-check the analysis against public incident reports. The results show that both ecosystems provide strong cryptographic foundations and the necessary building blocks to satisfy the invariants, while the main sources of real-world harm arise at the edges — where user intent can be misaligned, lifecycle steps can be abused, and verifier-side checks can be incomplete. The model explains these failures, distinguishes which controls matter most, and remains portable across providers and integration styles. In short, we offer a clear, testable way to reason about end-to-end security for modern eID systems and to interpret incident patterns through a small set of invariant properties.

Although validated against the Swedish ecosystems, the proposed state-machine abstraction is not tied to these specific implementations. As discussed in Section 8.2, the model captures structural invariants common to PKI-based national eID systems and federated identity architectures. These properties are independent of transport protocol or vendor-specific APIs, and therefore the framework can be applied — with minimal adaptation — to other certificate-based eID systems operating under national or cross-border trust frameworks such as eIDAS.

CRedit authorship contribution statement

Qinghua Wang: Writing – original draft, Writing – review & editing, Visualization, Validation, Supervision, Methodology, Investigation, Funding acquisition, Formal analysis, Conceptualization. **Omar Zarifa:** Writing – original draft, Methodology, Investigation, Conceptualization. **Nedim Kanat:** Writing – original draft, Methodology, Investigation, Conceptualization.

Declaration of competing interest

The authors declare the following financial interests/personal relationships which may be considered as potential competing interests: Qinghua Wang reports financial support was provided by Kristianstad University. Co-author Omar Zarifa and Co-author Nedim Kanat did a thesis project with the company Sigma Technology Embedded Network AB in the Spring 2025. Their previous work has contributed to some background knowledge for this work. The company was informed of this submission. If there are other authors, they declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgment

Open access publishing fee for this article was covered by Kristianstad University, Sweden.

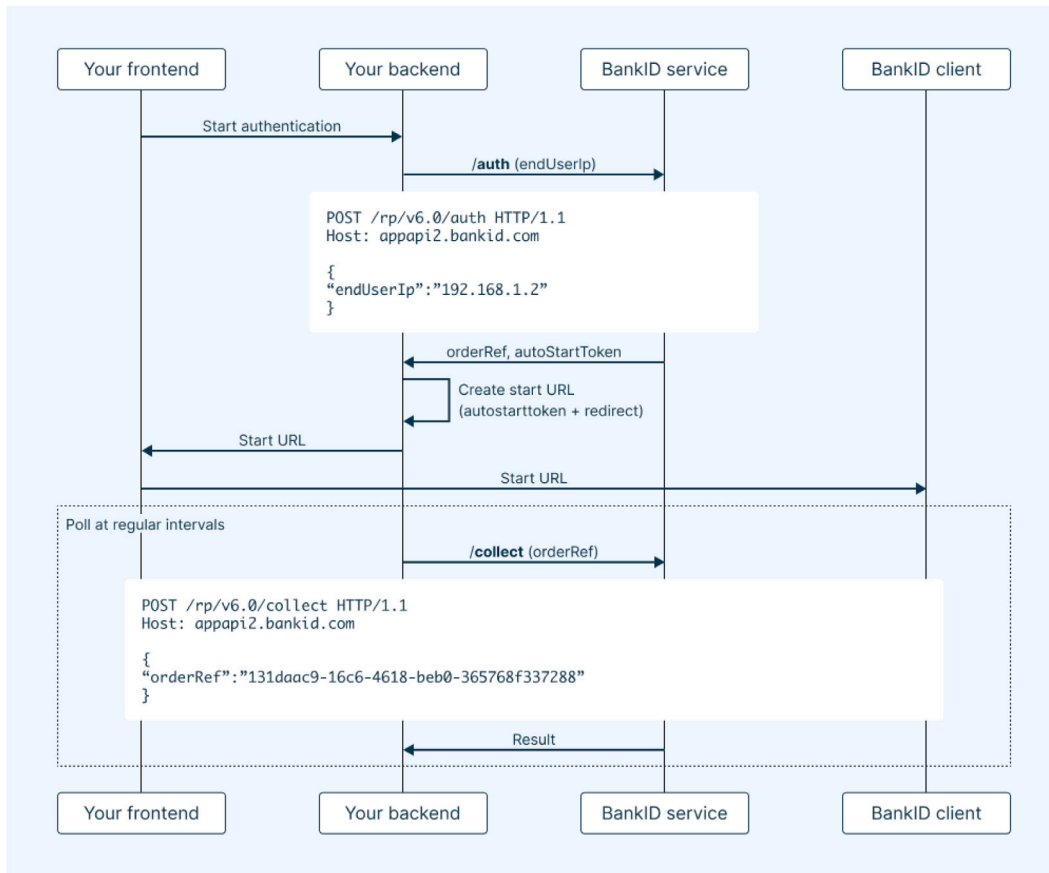


Fig. 7. Technical flow for BankID authentication on the same device.

Source: Reproduced from [Finansiell ID-Teknik BID AB \(2025b\)](#).

Appendix. Implementation notes and sequence diagrams for BankID and Freja eID

A.1. Purpose and scope

This appendix illustrates how the provider-agnostic state machines in Section 5.1 are instantiated by BankID and Freja eID. Field names, endpoints, and visual elements are vendor-specific and may evolve; the security invariants (freshness, session/origin binding, dynamic linking of human-readable action text) do not.

A.2. BankID implementation

Figs. 7 and 8 show the details of the technical processes for the identification and signature services on the same device and on another device. In both scenarios, the process begins when the user selects *Identify with BankID*. The frontend signals the backend, which calls the BankID `/auth` endpoint to initiate an authentication order. The BankID service responds with an `orderRef`, which is used throughout the session. From here, the flows diverge slightly.

In the same-device flow, the BankID service also returns an `autoStartToken`, which is passed back to the frontend. This token launches the BankID app directly on the user's device, allowing them to authenticate using a PIN or biometric method. After authentication, the app closes and the user is returned to the service interface.

The state machine for the same-device scenario has been illustrated in Fig. 3. There are seven states: S0 Idle, S1 OrderCreated, S2 AppLaunched, S3 UserAuth, S4 AssertionIssued, S5 RPVerified, and S6 Closed. The transition from S0 to S1 is characterized by the RP

initiates the communication by calling `POST /auth` (or `/sign` for signing), and receives `orderRef`, `autoStartToken`. The transition from S1 to S2 is characterized by the browser deep-links App with `autoStartToken`. The transition from S2 to S3 is activated when the user enters PIN/biometric. The transition from S3 to S4 is finished when the IdP issues assertion which is bound to `orderRef`. The transition from S4 to S5 is finished when RP via the `POST /collect(orderRef)` operation receives result (including the IdP-signed result and metadata), and verifies signature and bindings. S5 signifies a success in the authentication process.

In contrast, in the cross-device flow, the backend receives a `qrStartToken` and `qrStartSecret` in addition to the `orderRef`. These are used to generate a time-sensitive animated QR code, which is displayed by the frontend. The user then scans the QR code using the BankID app on their mobile device to complete authentication.

The state machine for the cross-device scenario can be illustrated as Fig. 4. There are eight states: S0 Idle, S1 OrderCreated, S2 QRDisplayed, S3 QRScanned, S4 UserAuth, S5 AssertionIssued, S6 RPVerified, and S7 Closed. The transition from S0 to S1 is characterized by the RP starts an order by calling `POST /auth` (or `/sign` for signing). The response returns `orderRef` together with `qrStartToken` and `qrStartSecret`. The transition from S1 to S2 is characterized by the frontend renders an animated, short-lived QR using the BankID guideline function `QR = Animate(qrStartToken, qrStartSecret, time)`, updating every second; stale frames must be rejected. The user opens the BankID app on the phone, selects "Scan QR", and scans a current frame; the IdP binds the scan to the correct `orderRef` via the embedded `qrStartToken`, and the state moves from S2 to S3. Inside the app the user performs PIN/biometric approval and the state moves to S4; the IdP proceeds with user authentication. When the IdP has an assertion ready for this

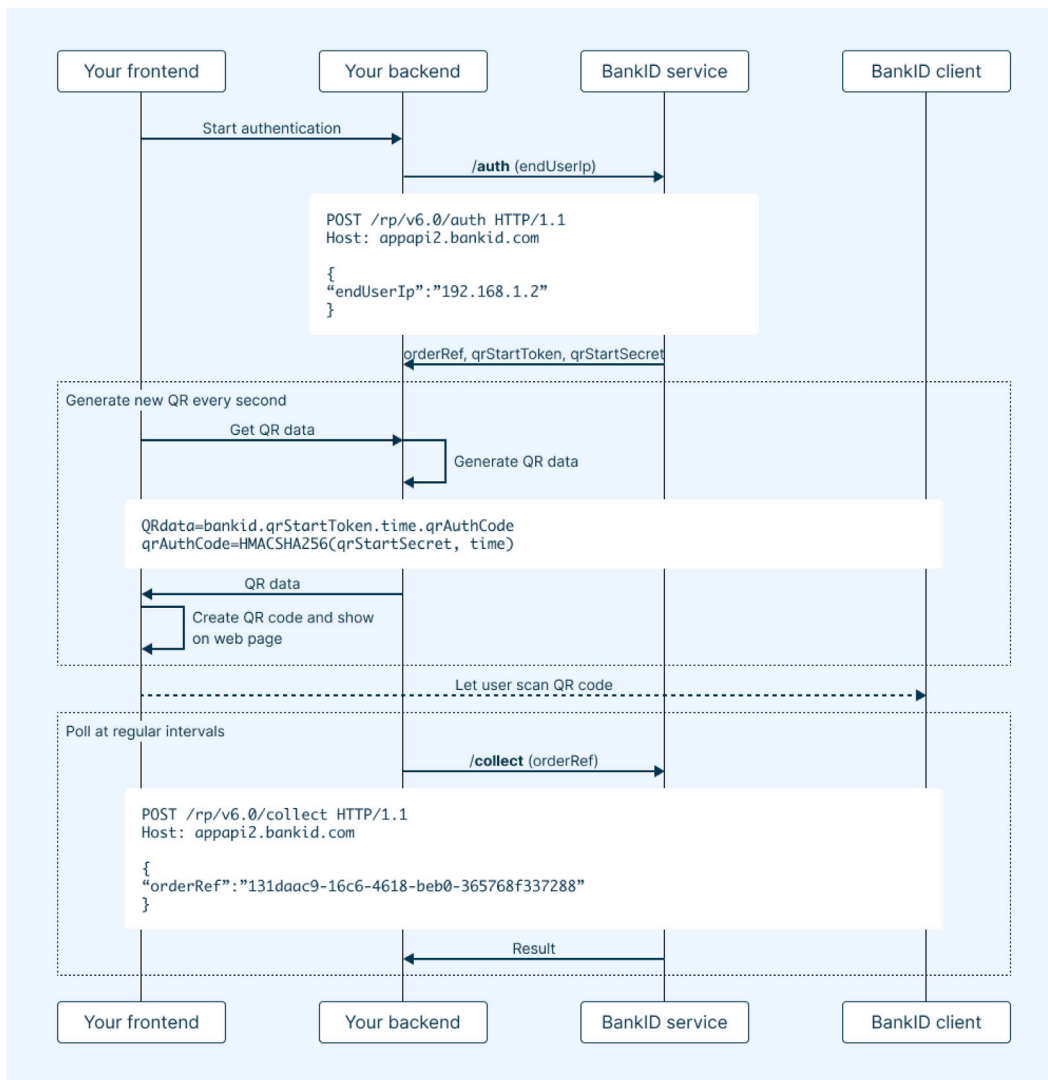


Fig. 8. Technical flow for BankID authentication on another device.
Source: Reproduced from [Finansiell ID-Teknik BID AB \(2025b\)](#).

orderRef, the state moves to S5. the RP polls *POST /collectorderRef* until *status = complete* (otherwise *pending/failed*). On completion, data is returned (including the IDP-signed result and metadata). The RP verifies the IDP signature and certificate chain and checks bindings to session, *orderRef*, origin (and, for signing, the hash of the human-readable purpose text). If all checks pass, the flow enters S6; otherwise it fails closed.

In both flows, the backend polls the */collect* endpoint every two seconds to monitor the status of the authentication session. Once the process is complete, BankID returns the user's personal number and other identifying information. As a security measure, the backend verifies that the IP address matches the initiating request to prevent session fixation. After successful verification, the user is authenticated/identified in the service.

A.3. Freja eID implementation

Similarly, Freja eID supports two comparable flows based on the platform initiating the authentication. Those are referred to as “on a desktop” and “on a mobile device” ([Signicat AS, 2026](#)). When authentication is initiated on a desktop, a static QR code is displayed. The user scans this QR code with the Freja eID mobile app, where they

authenticate to complete the process. This aligns with the cross-device model seen in Mobile BankID.

In contrast, when authentication is initiated directly on a mobile device, no QR code is shown to the user. Instead, the QR-based process is handled entirely in the background, and the user is redirected to the Freja eID app for authentication. This approach corresponds to the same-device model in BankID. In both Freja eID flows, explicit user consent is required to proceed.

Thus, while terminology and implementation details differ slightly, the core logic of device-based and cross-device authentication is conceptually aligned between BankID and Freja eID.

A.4. Middleware integration

While both BankID and Freja eID provide APIs for direct integration, many organizations opt to use third-party resellers or integrators to handle the technical implementation and certificate management. These third-party solutions can offer a simpler path to integration, allowing the RP to focus on their core business. The middleware does the heavy lifting — tracking BankID and Freja changes, rendering and refreshing QR codes, handling retries and callbacks, managing secrets, uptime, and monitoring — behind a single interface. The state machines

for the same-device scenario and for the cross-device scenario when a middleware is used are shown in Figs. 5 and 6.

With a middleware in the path, the BankID/Freja mobile apps and the IdP do not change. What changes for the RP are two hand-off checkpoints and a small set of middleware endpoints. In the state machines, we add:

- Same-device: new states S1M (Forwarded to middleware) and S4M (Completion received from middleware).
- Cross-device: new states S1M (Forwarded to middleware) and S5M (Completion received from middleware).

The RP talks to the middleware through a thin interface: a start call to create a session, an authenticated callback from the middleware when the IdP has a result, a consume call to fetch that result exactly once, and an optional cancel.

For the same-device via middleware scenario, S0→S1 is unchanged (the service creates a fresh order). S1→S1M occurs when the service calls the middleware's start endpoint (for example *POST /sessions/start*), which in turn calls the provider start (*/auth* or */sign* in BankID). The middleware returns the phone autostart link to the frontend. The app launches (S2) and the user approves (S3), the IdP issues the assertion (S4), and then S4→S4M when the middleware receives completion (typically by polling provider */collect* in BankID or a status/callback in Freja) and notifies the service via a signed webhook. The service performs a consume call (for example *POST /sessions/sid/consume*) to retrieve the provider-signed result exactly once, verifies it, and moves to success (S5) and close (S6). The optional cancel (*/sessions/sid/cancel*) makes the middleware call the provider's cancel.

For the cross-device via middleware scenario, S0→S1 is unchanged. S1→S1M occurs when the service calls the middleware's start; the middleware calls the provider and returns the QR seed (for BankID, *qrStartToken* and *qrStartSecret*, or a rendered QR feed). The frontend displays the animated, short-lived QR (S2), the phone app scans (S3) and the user approves (S4), the IdP issues the assertion (S5), and then S5→S5M when the middleware receives completion and posts a signed webhook to the service. The service calls consume once, verifies the provider signature and bindings, and moves to success (S6) and close (S7). As above, cancel is available and relayed to the provider.

Data availability

No data was used for the research described in the article.

References

- Aftonbladet, 2018a. Agneta, 79, fick kontot tömt av id-bedragare. <https://www.aftonbladet.se/nyheter/a/A2gqQj/agneta-79-fick-kontot-tomt-av-id-bedragare> (Accessed 18 September 2025).
- Aftonbladet, 2018b. Mamma blev nätrånad – banken bryr sig inte. <https://www.aftonbladet.se/debatt/a/ddprno/mamma-blev-natranad--banken-bryr-sig-inte> (Accessed 18 September 2025).
- Aftonbladet, 2025. Cyberattack mot bank-id. <https://www.aftonbladet.se/nyheter/a/73ARGK/driftstornning-paverkar-swish> (Accessed 18 September 2025).
- Aleksandar Laban, 2023. Obtaining a client TLS certificate. <https://frejaeid.atlassian.net/wiki/spaces/DOC/pages/34668551/Obtaining+a+Client+TLS+Certificate> (Accessed 20 September 2025).
- Aleksandar Laban, 2025. Authentication service. <https://frejaeid.atlassian.net/wiki/spaces/DOC/pages/2162802/Authentication+Service> (Accessed 20 September 2025).
- BankID, 2025a. Bankid and Swedish e-ID. <https://www.bankid.com/en/juridik-och-regelverk> (Accessed 20 September 2025).
- BankID, 2025b. Bankid approved as identification method in public services abroad. <https://www.bankid.com/om-oss/nyheter/bankid-godkant-for-identifiering-i-offentliga-e-tjanster-inom-eu> (Accessed 25 April 2026).
- BankID, 2025c. Disturbance/Driftstörning - incident report for BankID. <https://status.bankid.com/incidents/141s7wd1xdjp> (Accessed 18 September 2025).
- BankID Developers, 2025a. API overview. <https://developers.bankid.com/api-references/auth--sign/overview> (Accessed 20 September 2025).
- BankID Developers, 2025b. Getting started - verifying signatures. <https://developers.bankid.com/getting-started/signature> (Accessed 20 September 2025).
- Buccafurri, F., Fotia, L., Lax, G., Mammoliti, R., 2015. Enhancing public digital identity system (SPID) to prevent information leakage. In: Kő, A., Francesconi, E. (Eds.), *Electronic Government and the Information Systems Perspective*. Springer International Publishing, Cham, pp. 57–70. http://dx.doi.org/10.1007/978-3-319-22389-6_5.
- Bundesamt für Sicherheit in der Informationstechnik (BSI), 2026. Technical guidelines in the context of german electronic identities. https://www.bsi.bund.de/EN/Themen/Oeffentliche-Verwaltung/Elektronische-Identitaeten/Technische-Richtlinien/technische-richtlinien_node.html (Accessed 24 February 2026).
- DIGG, 2026. Godkända e-legitimationer och intygsfunktioner. <https://www.digg.se/digitala-tjanster/e-legitimering/om-e-legitimering/godkanda-e-legitimationer-och-intygsfunktioner> (Accessed 25 April 2026).
- Dragoljub Nesic, 2025. REST API documentation. <https://frejaeid.atlassian.net/wiki/spaces/DOC/pages/2162826/REST+API+Documentation> (Accessed 20 September 2025).
- European Union, 2023. Overview of pre-notified and notified eID schemes under eIDAS. <https://ec.europa.eu/digital-building-blocks/sites/spaces/EIDCOMMUNITY/pages/48762251/Overview+of+pre-notified+and+notified+eID+schemes+under+eIDAS> (Accessed 28 September 2025).
- European Union, 2024. Regulation (EU) no 910/2014 of the European parliament and of the council of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing directive 1999/93/EC. <http://data.europa.eu/eli/reg/2014/910/2024-10-18> (Accessed 27 May 2025).
- Federal Ministry of the Interior, Germany, 2025. Electronic identification with the german national identity card. <https://www.personalausweisportal.de/Webs/PA/EN/citizens/electronic-identification/electronic-identification-node.html> (Accessed 27 May 2025).
- Finansiell ID-Teknik BID AB, 2025a. Bankid in Sweden. <https://www.bankid.com/> (Accessed 27 May 2025).
- Finansiell ID-Teknik BID AB, 2025b. Developers. <https://developers.bankid.com/getting-started/use-cases> (Accessed 27 September 2025).
- Freja, 2025. Freja regulatory compliance. <https://org.frejaeid.com/en/trust/> (Accessed 20 September 2025).
- Freja eID Group AB, 2025. Freja. <https://frejaeid.com/> (Accessed 27 May 2025).
- Gjosteen, K., 2008. Weaknesses in BankID, a PKI-substitute deployed by Norwegian Banks. In: Mjølness, S.F., Mauw, S., Katsikas, S.K. (Eds.), *Public Key Infrastructure*. Springer Berlin Heidelberg, Berlin, Heidelberg, pp. 196–206. http://dx.doi.org/10.1007/978-3-540-69485-4_14.
- Jacomme, C., Kremer, S., 2021. An extensive formal analysis of multi-factor authentication protocols. *ACM Trans. Priv. Secur.* 24 (2), <http://dx.doi.org/10.1145/3440712>.
- Kingo, T., Aranha, D.F., 2023. User-centric security analysis of MitID: The Danish passwordless digital identity solution. *Comput. Secur.* 132, 103376. <http://dx.doi.org/10.1016/j.cose.2023.103376>, URL <https://www.sciencedirect.com/science/article/pii/S0167404823002869>.
- Kristianstadsbladet, 2025a. Konsumentverket om offerter och bank-id: "Ta ett andetag". <https://www.kristianstadsbladet.se/kristianstad/konsumentverket-om-offerter-och-bank-id-ta-ett-andetag/> (Accessed 18 September 2025).
- Kristianstadsbladet, 2025b. Solveig skulle köpa solceller – offert blev köp: "Riktigt fullt". <https://www.kristianstadsbladet.se/kristianstad/solveig-skulle-kopa-solceller-offert-blev-kop-riktigt-fult/> (Accessed 18 September 2025).
- Logius, 2025. Digid. <https://www.digid.nl/en/> (Accessed 28 September 2025).
- MitID partnership, 2025. MitID. <https://www.mitid.dk/> (Accessed 27 May 2025).
- Parsovs, A., 2020. Estonian electronic identity card: Security flaws in key management. In: 29th USENIX Security Symposium (USENIX Security 20). USENIX Association, pp. 1785–1802, URL <https://www.usenix.org/conference/usenixsecurity20/presentation/parsovs>.
- Radio Sweden, 2018. First sentences for "Bank ID" fraud. <https://www.sverigesradio.se/artikel/7004845> (Accessed 18 September 2025).
- Sciarretta, G., Carbone, R., Ranise, S., Viganò, L., 2020. Formal analysis of mobile multi-factor authentication with single sign-on login. *ACM Trans. Priv. Secur.* 23 (3), <http://dx.doi.org/10.1145/3386685>.
- Sharif, A., Ranzi, M., Carbone, R., Sciarretta, G., Marino, F.A., Ranise, S., 2022. The eIDAS regulation: A survey of technological trends for European electronic identity schemes. *Appl. Sci.* 12 (24), <http://dx.doi.org/10.3390/app122412679>, URL <https://www.mdpi.com/2076-3417/12/24/12679>.
- Signicat AS, 2026. About Freja eID. <https://developer.signicat.com/identity-methods/freja/about-freja/> (Accessed 25 April 2026).
- Svensk E-Identitet, 2021. Tillitsnivåer och LoA - vi reder ut begreppen. <https://e-identitet.se/news/vilken-loa-niva-behover-ni/> (Accessed 27 May 2025).

- Svensk Handel, 2024. Falska appar som ser ut som Freja eID i omlopp - så kollar du om appen är äkta!. <https://www.svenskhandel.se/sakerhet/sakerhetsnytt/falska-appar-som-ser-ut-som-freja-eid-i-omlopp-sa-kollar-du-om-appen-ar-akta> (Accessed 18 September 2025).
- SVT, 2024. De utsattes för samma bedrägeri – bara en fick pengarna tillbaka av banken. <https://www.svt.se/nyheter/lokalt/uppsala/de-utsattes-for-samma-bedrageri-endast-en-fick-pengarna-tillbaka-av-banken> (Accessed 18 September 2025).
- SVT, 2025. Överbelastningsattack mot Bank-id – störningarna pågick i tre timmar. <https://www.svt.se/nyheter/inrikes/driftstornig-i-bankid-ligger-nere-for-manga-anvandare> (Accessed 18 September 2025).
- Sweden Connect, 2020. Introduction to the Swedish eID framework. https://docs.swedenconnect.se/technical-framework/january-2020/pdf/00_-_Swedish_eID_Framework_-_Introduction.pdf (Accessed 27 May 2025).
- Sweden Connect, 2024. Introduction to the Sweden connect technical framework. https://docs.swedenconnect.se/technical-framework/latest/00_-_Swedish_eID_Framework_-_Introduction.html (Accessed 20 September 2025).
- The Supreme Court, Sweden, 2022. Supreme court's judgement. <https://www.domstol.se/globalassets/filer/domstol/hogstodomstolen/avgoranden/engelska-oversattningar/t-4623-21-eng.pdf> (Accessed 18 September 2025).
- The Swedish Agency for Digital Government (Digg), 2024. Deployment profile for the Swedish eID framework. https://docs.swedenconnect.se/technical-framework/latest/02_-_Deployment_Profile_for_the_Swedish_eID_Framework.html (Accessed 20 September 2025).
- Verhaeghe, P., Lapon, J., De Decker, B., Naessens, V., Verslype, K., 2009. Security and privacy improvements for the Belgian eID technology. In: Gritzalis, D., Lopez, J. (Eds.), *Emerging Challenges for Security, Privacy and Trust*. Springer Berlin Heidelberg, Berlin, Heidelberg, pp. 237–247. http://dx.doi.org/10.1007/978-3-642-01244-0_21.
- Wang, Q., 2026. Formal security analysis of Swedish BankID. In: *11th IEEE European Symposium on Security and Privacy (EuroS&P)*. Lisbon, to appear.